INTECO

Instituto Nacional
de Tecnologías
de la Comunicación

C· digo Activo: IS-TEOR-RSKM02
Nombre Activo: Gu²a avanzada de Gesti· n de Riesgos
Ver. Activo: 1.01 [17/9/12]
Copia de Versi· n Externa: Inteco ver. dic/08

GUÍA AVANZADA DE GESTIÓN DE RIESGOS

LNCS

Diciembre 2008

Instituto Nacional
de Tecnologías
de la Comunicación

AVISO LEGAL

- CMMI® es una marca registrada en la Oficina de Marcas y Patentes de EEUU por la Universidad Carnegie Mellon
- Las distintas normas ISO mencionadas han sido desarrolladas por la International Organization for Standardization.
- PMBOK® es una marca registrada por el Project Management Institute, Inc.

Todas las demás marcas registradas que se mencionan, usan o citan en la presente guía son propiedad de los respectivos titulares.

INTECO cita estas marcas porque se consideran referentes en los temas que se tratan, buscando únicamente fines puramente divulgativos. En ningún momento INTECO busca con su mención el uso interesado de estas marcas ni manifestar cualquier participación y/o autoría de las mismas.

Nada de lo contenido en este documento debe ser entendido como concesión, por implicación o de otra forma, y cualquier licencia o derecho para las Marcas Registradas deben tener una autorización escrita de los terceros propietarios de la marca.

Por otro lado, INTECO renuncia expresamente a asumir cualquier responsabilidad relacionada con la publicación de las Marcas Registradas en este documento en cuanto al uso de ninguna en particular y se eximen de la responsabilidad de la utilización de dichas Marcas por terceros.

El carácter de todas las guías editadas por INTECO es únicamente formativo, buscando en todo momento facilitar a los lectores la comprensión, adaptación y divulgación de las disciplinas, metodologías, estándares y normas presentes en el ámbito de la calidad del software.

ÍNDICE

1. INTRODUCCIÓN 7
1.1. Conceptos 7
1.2. ¿Qué es un riesgo? 9
1.2.1. Clasificación de riesgos 11
1.3. ¿En qué consiste la gestión de riesgos de un proyecto? 14
1.4. ¿Qué es un plan de gestión de riesgos? 16
1.5. Roles y responsabilidades dentro de la gestión de riesgos 16
2. ACTIVIDADES DE GESTIÓN DE RIESGOS 20
2.1. Desarrollar un plan de gestión de riesgos 21
2.1.1. Dependencias 22
2.1.2. Tareas para la planificación de gestión de riesgos 22
2.2. Identificar riesgos 24
2.2.1. Dependencias 25
2.2.2. Tareas para identificar riesgos 25
2.3. Analizar riesgos 28
2.3.1. Tareas para el análisis de riesgos 29
2.4. Planificar respuestas a los riesgos 34
2.4.1. Tareas para la planificación de respuestas a los riesgos 35
2.4.2. Herramientas 38
2.5. Controlar y monitorizar riesgos 39
2.5.1. Dependencias 40
2.5.2. Tareas para controlar y monitorizar riesgos 40
2.5.3. Herramientas 42
2.6. Cierre de la gestión de riesgos 42
2.6.1. Dependencias 43
2.6.2. Tareas del cierre de gestión de riesgos 43
3. ARTEFACTOS RELACIONADOS CON GESTIÓN DE RIESGOS 44
4. ENFOQUE DE ALGUNOS MODELOS 45
4.1. CMMI® vs SPICE 45
4.2. PMBOK® vs PRINCE2 46
5. ANEXO I: MÉTODOS DE IDENTIFICACIÓN DE RIESGOS 50

5.1. Técnicas de identificación de riesgos 50
5.1.1. Técnicas de Recopilación de Información 50
5.1.2. Técnica de organización de información 51
5.1.3. Análisis mediante lista de control 51
5.1.4. Análisis de suposiciones 51
5.1.5. Técnicas de diagramación 52
5.2. Buenas prácticas 52

6. ANEXO II: METODOLOGÍAS Y TÉCNICAS DE ANÁLISIS DE RIESGOS 53

6.1. Técnicas de Análisis de riesgos 53
6.1.1. Técnicas de valoración cualitativa de riesgos (análisis cualitativo) 53
6.1.2. Técnica de valoración cuantitativa (análisis cuantitativo) 53
6.2. Metodologías 55
6.2.1. MAGERIT 55
6.2.2. OCTAVE 56
6.2.3. NIST 800-30ª 57

7. ANEXO III: ESTRATEGIAS DE RESPUESTAS 59

7.1. Estrategias para Riesgos Negativos o Amenazas 59
7.1.1. Evitar 59
7.1.2. Transferir 59
7.1.3. Mitigar 60
7.2. Estrategias para Riesgos Positivos u Oportunidades 60
7.2.1. Explotar 60
7.2.2. Compartir 60
7.2.3. Mejorar 61
7.3. Estrategia Común ante Amenazas y Oportunidades 61
7.3.1. Aceptar 61
7.4. Estrategia de Respuesta para Contingencias 61

8. GLOSARIO 63

9. REFERENCIAS 66

ÍNDICE DE TABLAS

Tabla 1 Clasificación de fuentes internas 12

Tabla 2 Clasificación de fuentes externas 12

Tabla 3 Clasificación de riesgos respecto al impacto 13

Tabla 4 Roles y responsabilidades 19

Tabla 5 Entradas, salidas y herramientas del plan de gestión de riesgos 22

Tabla 6 Entradas, salidas y herramientas de identificación de riesgos 24

Tabla 7 Entradas, salidas y herramientas de análisis de riesgosDependencias 28

Tabla 8 Impacto de riesgos 30

Tabla 9 Probabilidad de riesgos 31

Tabla 10 Matriz probabilidad - impacto 32

Tabla 11 Entradas, salidas y herramientas de planificación de respuesta de riesgos 35

Tabla 12 Ejemplo entrada registro de riesgos 38

Tabla 13 Entradas, salidas y herramientas de control y monitorización de riesgos 40

Tabla 14 Entradas, salidas y herramientas del cierre de gestión de riesgos 43

Tabla 15 Estrategias de respuesta de riesgos 62

Tabla 16 Ejemplo estrategias asignadas a riesgos 62

ÍNDICE DE FIGURAS

Figura 1 Relación entre conceptos relacionados con riesgos 8

Figura 2 Relación coste-riesgo – Fuente PMBOK® 10

Figura 3 Actividades gestión de riesgos 21

Figura 4 Ejemplo de una Estructura de Desglose de Riesgo (RBS), según PMBOK® 23

Figura 5 Procesos metodología Octave 57

Figura 6 Flowchart de metodología de evaluación de riesgos. Fuente NIST 800-30ª 58

1. INTRODUCCIÓN

Los riesgos normalmente son considerados como amenazas para el proyecto, y como tales deben ser minimizados. A menudo, la mejor aproximación es que cada riesgo sea examinado para determinar si puede transformarse en oportunidad.

En lugar de tratar los riesgos como algo que debe evitarse, deberían buscarse oportunidades para transformar un evento desfavorable en algo positivo. Por ejemplo, en un proyecto se detecta un riesgo que consiste en que puede que la WAN no tenga suficiente capacidad para soportar una nueva aplicación. En este caso, en lugar de minimizar las funcionalidades de la aplicación para adaptarla a la capacidad de la WAN, se podría tratar dicho riesgo como una oportunidad, y trabajar junto con otras unidades de negocio para desarrollar un acuerdo para expandir la WAN permitiendo a otros departamentos mantener las funcionalidades de la aplicación previamente frenadas por la capacidad de la WAN.

1.1. CONCEPTOS

Antes de comenzar a describir en qué consiste el proceso de gestión de riesgos es importante saber diferenciar ciertos conceptos que a menudo se confunden o incluso se utilizan indistintamente para hacer referencia al riesgo. A lo largo de esta guía van a parecer conceptos tales como amenaza, impacto, vulnerabilidad,… para definir y describir aspectos relacionados con los riesgos. Por ello, en este apartado van a aclararse ciertos conceptos de tal forma que al leer el resto de la guía no haya confusiones.

Activo

Cualquier recurso de SW, HW, datos, administrativo, físico, de personal, de comunicaciones…

Por ejemplo servidores, bases de datos, redes, usuario, aplicaciones, sistemas operativos, dinero, información…

Vulnerabilidad

Una vulnerabilidad es una debilidad que puede ser ‘activada’ de forma accidental o intencionadamente. Es un factor de riesgo interno de un elemento expuesto a una amenaza de ser susceptible a sufrir un daño y de encontrar dificultades en recuperarse posteriormente.

Por ejemplo, cuentas de usuarios sin contraseña; el personal externo no registra su entrada y salida a las instalaciones; falta de directrices para la construcción de contraseñas; no hay un software de control de accesos; no contar con un plan de recuperación de desastres.

El análisis de la amenaza en un sistema IT debe incluir un análisis de las vulnerabilidades asociadas al entorno del sistema. El objetivo es desarrollar una lista de vulnerabilidades que pueden transformarse en fuente potencial de amenazas.

Amenaza

Una amenaza es la posibilidad de que se produzca una determinada vulnerabilidad de forma satisfactoria. Una fuente de amenazas no plantea un riesgo cuando no hay vulnerabilidades que puedan ser 'activadas'.

Al determinar la probabilidad de ocurrencia de una amenaza, se deben tener en cuenta las fuentes de las amenazas, las vulnerabilidades potenciales y los controles existentes.

Es decir, una amenaza es una circunstancia o evento con la capacidad de causar daño a un sistema, entendiendo como daño una forma de destrucción, revelación o modificación de datos.

Ejemplos:

- Naturales: Terremotos que destruyan el centro de cómputo.
- Humanas: Fraude realizado al modificar los saldos de cuentas por cobrar.
- Software: Cambios no autorizados al sistema que realicen cálculos incorrectos.

Impacto

El impacto es la materialización de un riesgo; una medida del grado de daño o cambio sobre un activo, entendiendo como riesgo la probabilidad de que un evento desfavorable ocurra y que tendría un impacto negativo si se llegase a materializar. Se hará una descripción más detallada acerca de la definición de riesgo en el siguiente apartado.

Ejemplos:

- Retraso en la ejecución y conclusión de actividades de negocio
- Pérdida de oportunidad y efectividad en la operación.
- Falta de credibilidad frente a clientes.
- Divulgación de información confidencial.



Figura 1 Relación entre conceptos relacionados con riesgos

Por último vamos a ver el concepto de suposición que tiende a crear confusión al utilizarlo en el entorno de los riesgos.

Suposiciones

Las suposiciones son afirmaciones aceptadas como reales pero sin ningún tipo de prueba que las sustente. También es verdad que con el tiempo se puede determinar si las suposiciones son verdaderas o falsas. Las suposiciones y los riesgos son conceptos muy similares. Se podría entender que una suposición es un tipo de riesgo.

Las suposiciones y los riesgos comparten dos características clave:

- Incertidumbre (probabilidad)
- Consecuencia (impacto)

Por esta razón las suposiciones podrán beneficiarse del análisis cualitativo y del uso de una matriz probabilidad-impacto, que se tratarán en apartados posteriores de la guía.

Normalmente las suposiciones con baja probabilidad e impacto alto o muy alto se convierten en riesgo, en cuyo caso no deben ser ignoradas, sino gestionadas como riesgos. Por ejemplo, si se desarrolla una aplicación para una empresa que funciona con un determinado sistema operativo, se podría suponer que todos los usuarios de dicha empresa trabajan sobre ese sistema operativo. La probabilidad de que haya algún usuario que utilice uno diferente es muy baja, pero si ocurre el impacto será muy alto ya que esa persona no podrá utilizar la aplicación que necesita para desarrollar sus labores en la empresa. Por lo tanto esta suposición que se hizo en un principio se ha convertido en un riesgo.

Una manera de identificar suposiciones es la de llevar a cabo análisis de riesgos cualitativos e identificar aquellos elementos con riesgo bajo y medio. Algunos de estos riesgos medios o bajo pueden ser candidatos a ser suposiciones. El problema vendría si estas suposiciones fuesen incorrectas, ya que habría implicaciones negativas.

Las suposiciones deberían ser identificadas, analizadas de forma cualitativa, controladas y documentadas, aunque no es necesario realizar un análisis cuantitativo ni crear un plan de respuestas sobre las mismas. Todos estos temas se verán más adelante con más detalle.

1.2. ¿QUÉ ES UN RIESGO?

En el apartado anterior ya se definió de forma breve qué es un riesgo, pero de forma genérica. Esta guía se centrará en los riesgos dentro de un proyecto.

Un riesgo de un proyecto es un evento o condición incierto que, si se produce, tendrá un efecto positivo o negativo sobre al menos un objetivo del proyecto, como tiempo, coste, alcance o calidad, es decir, cuando el objetivo de tiempo de un proyecto es cumplir con el cronograma acordado; cuando el objetivo de coste del proyecto es cumplir con el coste acordado, etc.

Las organizaciones perciben los riesgos por su relación con las amenazas al éxito del proyecto o por las oportunidades de mejorar las posibilidades de éxito del proyecto. Los riesgos que son amenazas para el proyecto pueden ser aceptados si el riesgo está en equilibrio con el beneficio que puede obtenerse al tomarlo.

Los riesgos que constituyen oportunidades, como la aceleración del trabajo que puede lograrse asignando personal adicional, pueden ser monitorizados para beneficiar los objetivos del proyecto.

Las personas y, por extensión, las organizaciones, tienen actitudes hacia el riesgo que afectan tanto a la exactitud de la percepción del riesgo como a la forma en que responden a él. Las actitudes respecto al riesgo deberían hacerse explícitas siempre que sea posible. Para cada proyecto, se debe desarrollar un enfoque consistente hacia el riesgo que cumpla con los requisitos de la organización, y la comunicación acerca del riesgo y su tratamiento deben ser abiertos y honestos. Las respuestas a los riesgos reflejan el equilibrio percibido de una organización entre tomar y evitar los riesgos.

Para tener éxito, la organización debe estar comprometida a tratar la gestión de riesgos de forma proactiva y consistente durante todo el proyecto.

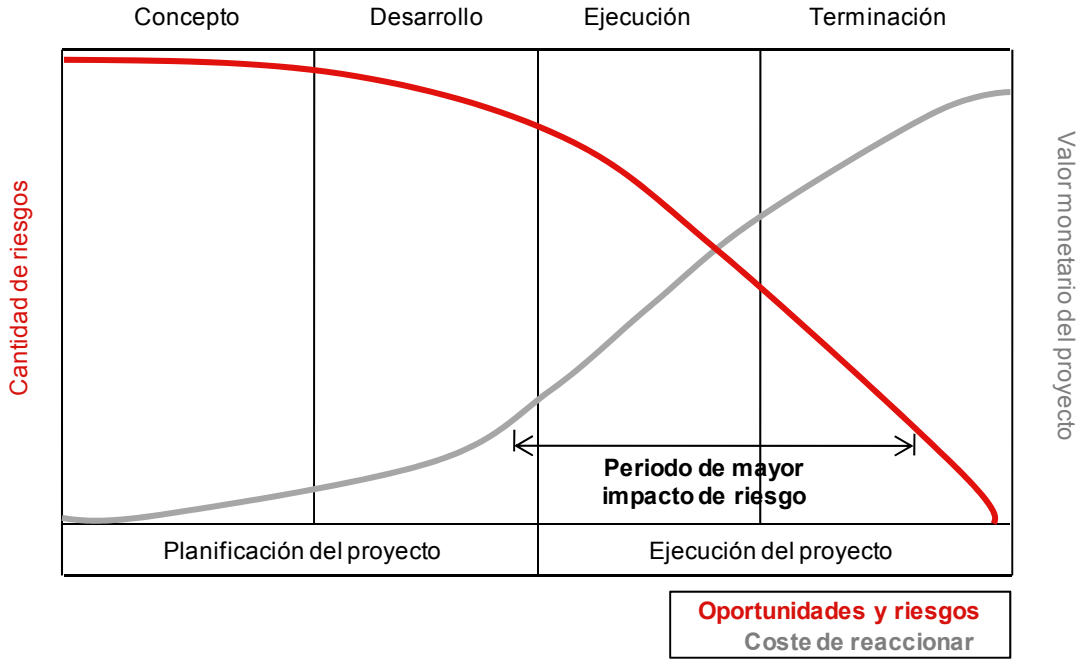


Figura 2 Relación coste-riesgo – Fuente PMBOK®

Un riesgo puede tener una o más causas y, si se produce, uno o más impactos. Por ejemplo, una causa puede ser necesitar un permiso ambiental para hacer el trabajo, o que se asigne personal limitado para diseñar el proyecto. El evento de riesgo en ambos casos sería que la agencia que otorga el permiso podría tardar más de lo previsto en emitir el permiso, o que el personal de diseño disponible y asignado no sea suficiente para la actividad. Si ocurre alguno de estos eventos inciertos, puede haber un impacto sobre el coste, el cronograma o el rendimiento del proyecto.

Las condiciones de riesgo pueden incluir aspectos del entorno del proyecto o de la organización que pueden contribuir al riesgo del proyecto, tales como prácticas deficientes

de dirección de proyectos, la falta de sistemas de gestión integrados, múltiples proyectos concurrentes o la dependencia de participantes externos que no pueden ser controlados.

El riesgo del proyecto tiene su origen en la incertidumbre que está presente en todos los proyectos. Existen distintos tipos de riesgos. Los **riesgos conocidos** son aquellos que han sido identificados y analizados, y es posible planificar las acciones a tomar al respecto tal y como se verá en apartados sucesivos. Los **riesgos desconocidos** no pueden gestionarse de forma proactiva, y una respuesta prudente del equipo del proyecto puede ser asignar una contingencia general contra dichos riesgos, así como contra los riesgos conocidos para los cuales quizás no sea rentable o posible desarrollar respuestas proactivas.

El riesgo está compuesto de tres componentes esenciales:

- un evento definible
- probabilidad de ocurrencia
- consecuencia de la ocurrencia (impacto)

Otras de las características que distinguen a los riesgos son:

- Los riesgos son situacionales: los riesgos varían drásticamente de una situación a otra. Un uso eficiente de las herramientas y técnicas puede ayudar a mitigar dichos riesgos.
- Los riesgos pueden ser interdependientes: los riesgos a menudo están relacionados. La respuesta a un riesgo puede provocar un nuevo riesgo o aumentar el impacto de uno ya existente.
- Los riesgos dependen de la magnitud: un determinado riesgo podría ser aceptado por ejemplo, si los beneficios y oportunidades potenciales son mayores.
- Los riesgos están basados en valor: el nivel de tolerancia del riesgo varía de una persona a otra. Tanto las personas como la compañía influyen en la tolerancia al riesgo.
- Los riesgos están basados en tiempo: el riesgo es un fenómeno del futuro causado por acciones actuales. El tiempo además afecta a la percepción del riesgo. Dependiendo de cuándo ocurra el riesgo, la percepción cambia.

1.2.1. Clasificación de riesgos

Usar categorías de riesgos ayuda a identificar nuevos riesgos. Las categorías pueden ser distintas dependiendo del tipo de proyecto. A continuación se proponen algunas:

Los riesgos se pueden clasificar según sus fuentes, es decir, según las causas que los provocan. Existen dos grandes categorías en la que agrupar las fuentes de los riesgos:

- Fuentes de riesgos internos
- Fuentes de riesgos externos.

Los riesgos externos son aquellos que tienen sus fuentes fuera de la organización que esponsoriza el proyecto. Sin embargo, los riesgos internos tienen sus fuentes dentro de la

organización, incluyendo el proyecto. Los riesgos internos pueden ser controlados por el equipo de proyecto. Obviamente, las fuentes de los riesgos y la exposición a pérdidas potenciales son factores dependientes del proyecto.

Las siguientes tablas muestran ejemplos de la clasificación de las fuentes de los riesgos tanto internos como externos que ayudan a la identificación de los mismos.

Tecnología	Programación	Financiera	Contractual y legal
Tecnología nueva o no probada	Disponibilidad de recursos	Fondos y presupuesto	Propiedad intelectual
Disponibilidad de experiencia técnica	Planificación inadecuada	Exactitud de estimación	Políticas de gobierno
Actuación del subcontratista/vendedor	Restricciones de programación	Cambio en coste de material	Derechos de datos
Personalización (riesgos de diseño)	Información insuficiente		Ambigüedades de contrato
Transición desde diseño a producción	Dependencias de la empresa		Multas
Disponibilidad de materiales	Dependencias del cliente		Derechos de patentes o incumplimientos

Tabla 1 Clasificación de fuentes internas

Impredecibles	Predecibles pero inciertos
Cambios reguladores	Cambios de mercados
Impacto ambiental, del entorno, sociales …	Tasación
Desastres naturales	Inflación
Interés público	Tipo de cambio
Relaciones industriales (huelga)	Subcontratista o partner políticos
Mercados dinámicos	Mercados dinámicos

Tabla 2 Clasificación de fuentes externas

Si clasificásemos los riesgos en función de su impacto tendríamos:

Riesgos	Impacto
Conocido	Conocido
Conocido	No Conocido
No Conocido	No Conocido

Tabla 3 Clasificación de riesgos respecto al impacto

Los primeros dos tipos de riesgos son visibles y pueden planificarse. El tercer grupo sin embargo no es tan evidente y es difícil de planificar. En el Anexo III se proponen unas estrategias de respuesta que pueden ayudar a su gestión.

Los riesgos conocidos que son controlables pueden considerarse durante la planificación del proyecto. Entre estos riesgos está por ejemplo: el uso de nueva tecnología, o el aumento en la complejidad, rendimiento o agresividad en las fechas de entrega.

Sin embargo, el equipo de trabajo no tiene apenas influencia sobre riesgos conocidos que no sean controlables. Entre ellos están por ejemplo: pérdida de miembros clave en el equipo de trabajo, reorganización del negocio, u otros factores externos. En estos casos, será necesario crear unos planes de contingencia y de reserva para tratar cada riesgo en caso de que ocurriera.

Los riesgos no conocidos no pueden ser planificados, pero sí se podría dejar una reserva de presupuesto y de tiempo por si apareciesen estas dificultades no esperadas.

A continuación aparece un listado con ejemplos de riesgos clasificados en función de una serie de factores (programación, recursos…) para ver otro posible enfoque de la clasificación de riesgos. Como se ha comentado con anterioridad, la empresa decidirá cuál será la clasificación más adecuada en función de los proyectos que se lleven a cabo.

Riesgos de planificación/cronograma:

- Tareas con larga duración sin hitos bien definidos
- Tareas de camino crítico
- Tareas con múltiples predecesores
- Tareas estimadas de forma no realista
- Tareas dependientes de organizaciones externas
- Grandes hitos
- Cronograma sin suposiciones documentadas
- Restricciones de planificación
- Insuficiente información

Riesgos de recursos:

- Pérdida de contribuidores críticos
- Trabajo con proveedores no fiables
- Tareas no asignadas a nadie
- Formación
- Hardware y/o software

Riesgos financieros

- Desajustes en presupuesto
- Cambios en el coste de material

Riesgos de alcance y calidad

- Nueva tecnología no probada (incertidumbre)
- Cambios en los requisitos del cliente
- Herramientas no disponibles
- Alta tasa de defectos
- Alto impacto de negocio

Riesgos generales

- Mal entendimiento (requisitos, diseño…)
- Seguridad
- Pérdida de patrocinio
- Dificultades de lenguaje o comunicación
- Pérdida de información

1.3. ¿EN QUÉ CONSISTE LA GESTIÓN DE RIESGOS DE UN PROYECTO?

La gestión de riesgos se lleva a cabo:

- En la elaboración de una propuesta, cuando se planifica el proyecto
- A intervalos regulares durante la vida del proyecto: por ejemplo, como parte de los informes de estado del proyecto.
- Cuando hay un cambio de alcance en el proyecto

Por tanto, es un proceso iterativo y recurrente a lo largo de toda la vida del proyecto. El propósito de la gestión de riesgos es minimizar la probabilidad y consecuencias de los riesgos negativos (o amenazas) y maximizar la probabilidad y consecuencias de los riesgos positivos (u oportunidades) identificados para el proyecto de tal forma que los objetivos de los proyectos se cumplan. Esto se consigue siguiendo una serie de pautas:

- Identificar todos los riesgos conocidos del proyecto
- Realizar una evaluación de la probabilidad de ocurrencia y del impacto potencial
- Cuantificar cual sería el coste de los riesgos en caso de que ocurrieran
- Crear planes de acción para gestionar los riesgos de alta prioridad
- Reconocer y gestionar los riesgos lo antes posible

El proceso de gestión de riesgos comienza cuando se identifica una oportunidad de negocio y concluye cuando la solución ha sido aceptada por el cliente. El equipo de proyecto deberá entregar una solución que satisfaga las necesidades del cliente tal y como se especificaron en el alcance del proyecto, en el tiempo acordado y cumpliendo los términos y condiciones del contrato. Si falla alguno de estos aspectos podría provocar un aumento del coste del proyecto, y por lo tanto una reducción del beneficio.

Al gestionar los riesgos de forma efectiva, conseguiremos cumplir los objetivos de negocio y del proyecto, y de esta forma se evitarán problemas que pudieran causar pérdidas inesperadas y no planificadas.

Cuando los requisitos del cliente generan riesgos inusuales, dichos riesgos deberían ser discutidos para evitar sorpresas, retrasos y costes. Además, este debate pondrá en conocimiento del cliente que las áreas de riesgos pueden requerir soluciones alternativas. En algunos casos, ciertos riesgos podrían llegar a ser propuestas alternativas o la base para futuras solicitudes de cambio. De esta manera la gestión de riesgos podría servir para identificar nuevos proyectos y oportunidades de negocio. Los elementos de riesgo pueden ser negociados con el cliente para reducir el riesgo y coste total del proyecto.

Los objetivos de la gestión de los riesgos del proyecto son aumentar la probabilidad y el impacto de los eventos positivos, y disminuir la probabilidad y el impacto de los eventos adversos para el proyecto. Las empresas normalmente están en entornos de negocio con riesgo, ya que los proyectos tienen riesgos. Al gestionar los riesgos de forma proactiva, se conseguirá mejorar el beneficio de la empresa. Otros de los beneficios que se obtienen al llevar a cabo una buena gestión de los riesgos son:

- Se reduce los costes del proyecto
- Se mejora la satisfacción del cliente
- Se incrementa la capacidad y probabilidades de éxito
- Facilita el desarrollo del proyecto
- Disminuye drásticamente las sorpresas en los proyectos
- Ayuda a la empresa a conseguir los objetivos de negocio y proyecto evitando problemas que podrían causar pérdidas inesperadas y no planificadas

1.4. ¿QUÉ ES UN PLAN DE GESTIÓN DE RIESGOS?

El **plan de gestión de riesgos** describe la estrategia que se va a seguir en el proyecto, y cómo las actividades de gestión de riesgos van a ser organizadas y llevadas a cabo durante la vida del proyecto.

El propósito del plan de gestión de riesgos es minimizar el impacto de los riesgos negativos y maximizar los riesgos positivos (oportunidades) identificados en el proyecto. Esto se logrará identificando todos los riesgos conocidos del proyecto, efectuando una valoración de la probabilidad de su ocurrencia y de su impacto potencial, y creando planes de acción para responder a los riesgos que lo requieran. El plan de gestión de riesgos define cómo enfocar y planificar las actividades de gestión de riesgos para un proyecto. Este proceso asegura que los esfuerzos de las actividades de gestión de riesgos son adecuados para la importancia que el proyecto tiene, tanto para el cliente como para la propia empresa. Por lo tanto un plan de riesgos debería describir:

- Una estrategia de gestión de riesgos
- Alcance del esfuerzo en gestión de riesgos
- Cómo se piensa llevar a cabo la identificación de riesgos
- Cómo se va a llevar a cabo el análisis de riesgos (cualitativo, cuantitativo, priorización)
- Cómo se va a llevar a cabo el plan de respuesta (no debe contener los propios planes de respuesta ni tratar riesgos concretos)
- Cómo se va a llevar a cabo la monitorización y control
- Presupuesto de gestión de riesgos
- Calendario de actividades de gestión de riesgos
- Roles y responsabilidades

El plan se crea durante la etapa de planificación del proyecto, aunque debería ser revisado a lo largo del mismo. Existe un mayor esfuerzo inicial en el desarrollo del plan, que luego decrece. El enfoque y la idoneidad de las actividades de gestión de riesgos deberán ser revisadas continuamente a lo largo del proyecto. Las distintas fases del proceso de gestión de riesgos serán descritas en apartados sucesivos.

La persona encargada de generar y mantener el plan de gestión de riesgos será el jefe de proyecto como se verá en el siguiente apartado (Roles y responsabilidades de riesgos). Sin embargo, puede tener aportaciones y colaboración de otros integrantes del proyecto (miembros del equipo, cliente…). Esta idea aplica a todas las fases.

1.5. ROLES Y RESPONSABILIDADES DENTRO DE LA GESTIÓN DE RIESGOS

El jefe de proyecto de la organización es el encargado de crear y de mantener actualizado el plan de gestión de riesgos. Además, deberá revisar y vigilar proactivamente el estado de

todos los riesgos del proyecto, recabando la información necesaria del equipo de proyecto, y volcarlos a un registro común de todo el proyecto. También debe mantener informado al cliente del estado de riesgos del proyecto en las reuniones de seguimiento.

El responsable de cada parte del proyecto (Gestión de sistemas, Gestión de fallos…) debe realizar el proceso de gestión de riesgos en la parte de alcance de la que es responsable, y hacer una puesta en común al inicio del proyecto con el jefe de proyecto. Durante el proyecto debe llevar a cabo la monitorización y control de los riesgos de los que es responsable, mandar las actualizaciones de su registro al jefe de proyecto y de escalar situaciones excepcionales al jefe de proyecto.

Los miembros del equipo de proyecto deben revisar los riesgos en las reuniones de seguimiento conjuntamente con el jefe de proyecto, deben llevar a cabo aquellos planes de respuesta de los que sean responsables, e informar al jefe de proyecto de la organización de posibles riesgos que detecten relacionados con el proyecto, así como colaborar en el proceso de gestión de los mismos cuando se considere necesario y así se acuerde mutuamente.

Los gerentes del proyecto, con la ayuda del cliente, deberán revisar los riesgos siempre que por su importancia así se requiera, y también llevarán a cabo aquellos planes de respuesta de los que sean responsables, informando al jefe de proyecto de posibles riesgos que detecten, y colaborando en el proceso de gestión de los mismos cuando se considere necesario.

A continuación se indican los roles más relevantes en las actividades llevadas a cabo durante las distintas fases del proceso de gestión de riesgos del proyecto.

Desarrollo del plan de gestión de riesgos

- Jefe de proyecto – Desarrolla y mantiene el plan de gestión de riesgos.
- Involucrado en el negocio – Proporciona información acerca del nivel de riesgo que se considera aceptable.
- Aceptador – Proporciona entradas sobre los criterios de aceptación de los entregables que puedan influenciar sobre el riesgo del proyecto.

Identificación de riesgos

- Jefe de proyecto – Identifica los riesgos del proyecto.
- Involucrado en el negocio – Proporciona información de históricos que sirvan de ayuda para la identificación de los riesgos del proyecto.
- Expertos en la materia - Proporciona información de históricos que sirvan de ayuda para la identificación de los riesgos del proyecto.
- Equipo del proyecto – Trabaja con el jefe del proyecto para identificar riesgos.

Análisis de riesgos

- Jefe de proyecto – Analiza los riesgos del proyecto.

- Involucrado en el negocio – Valida las suposiciones realizadas durante la planificación del proyecto y proporciona entradas sobre las probabilidades e impacto del riesgo.
- Expertos en la materia - Valida las suposiciones realizadas durante la planificación del proyecto y proporciona entradas sobre las probabilidades e impacto del riesgo.

Planificación de respuesta de riesgos

- Jefe de proyecto – Dirige el proceso de planificación de repuestas, identifica a los participantes y define los planes de respuesta de riesgos con la ayuda del equipo del proyecto.
- Involucrado en el negocio – Participan en el desarrollo de los planes de respuesta de cada riesgo individual y asumen la responsabilidad de sus planes.

Control y monitorización de riesgos

- Jefe de proyecto – Responsable final de la monitorización y control de riesgos. Es el responsable del mantenimiento del plan de riesgos.
- Involucrado en el negocio – Identifican nuevos riesgos y riesgos que han cambiado; evalúan la efectividad de la gestión de riesgos, los planes de respuesta y cualquier acción de respuesta.
- Responsable de un riesgo – Responsable del plan de respuesta de un riesgo.

Cierre de la gestión de riesgos

- Jefe de proyecto – Registra las lecciones aprendidas durante la gestión de riesgos y proporciona los resultados durante el cierre del proyecto.

	Jefe de proyecto	Involucrado en el negocio	Aceptador	Expertos en la materia	Equipo del proyecto	Responsable de un riesgo
Planificación gestión de riesgos	X	X	X			
Identificación de riesgos	X	X		X	X	
Análisis de riegos	X	X		X		
Planificación de respuesta de riesgos	X	X				
Control y monitorización de riesgos	X	X				X

Cierre de la gestión de riesgos	**X**					

Tabla 4 Roles y responsabilidades

NOTA: En algunos proyectos, el jefe o responsable del mismo puede delegar este proceso a otro miembro del equipo. Sin embargo toda la responsabilidad recae en el jefe de proyecto. Si un jefe de proyecto no ha sido identificado, el responsable oportuno se hará cargo de este proceso.

2. ACTIVIDADES DE GESTIÓN DE RIESGOS

La gestión de los riesgos del proyecto incluye los procesos relacionados con la planificación de la gestión de riesgos, la identificación y el análisis de riesgos, las respuestas a los riesgos, y el seguimiento y control de riesgos de un proyecto; la mayoría de estos procesos se actualizan durante el proyecto:

- Desarrollar un plan de gestión de riesgos – Decidir cómo planificar las tareas relacionadas con la gestión de riesgos para un proyecto, es decir, cómo se va a realizar dicha gestión.
- Identificar riesgos – Determinar qué riesgos pueden afectar al proyecto y documentar sus características.
- Analizar riesgos - Realizar un análisis cuantitativo de los riesgos y condiciones para priorizar sus efectos sobre los objetivos del proyecto, medir la probabilidad y consecuencias de los riesgos y estimar sus implicaciones sobre los objetivos del proyecto.
- Planificar la respuesta de riesgos – Creación de planes de acción para gestionar los riesgos identificados. Desarrollar procedimientos y técnicas para aumentar las oportunidades y reducir las amenazas sobre los objetivos del proyecto.
- Controlar y monitorizar riesgos – Monitorizar, revisar y actualizar el estado de los riesgos y los planes de respuesta. Monitorizar riesgos residuales, identificar nuevos riesgos, buscar la presencia de “disparadores” de riesgo, ejecutar planes de reducción de riesgos y evaluar su efectividad a través del ciclo de vida del proyecto.
- Cierre de la gestión de riesgos – documentar lecciones aprendidas como parte del proceso de cierre del proyecto, registrar mejoras para procesos de gestión de riesgos, plantillas y herramientas y para otros procesos del proyecto, plantillas y herramientas para reducir futuras exposiciones a riesgos.

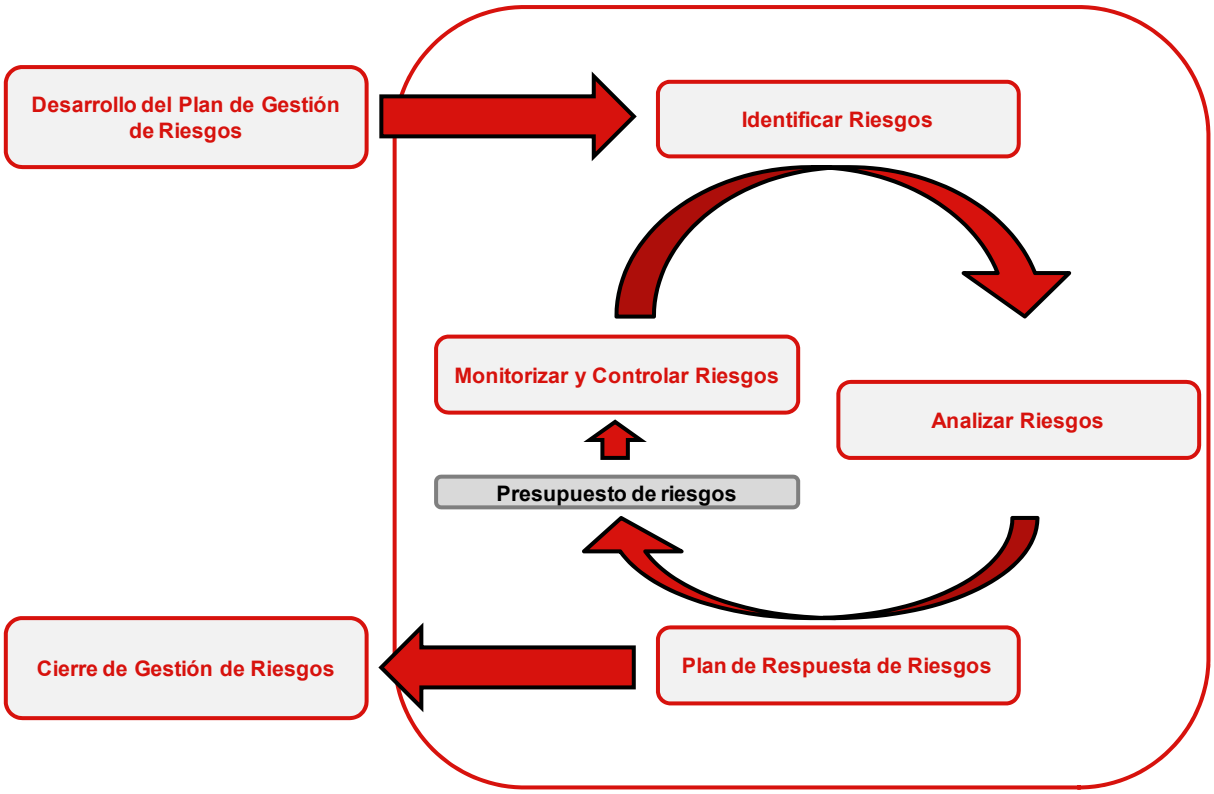


Figura 3 Actividades gestión de riesgos

Estos procesos interactúan entre sí y también con los procesos de las demás áreas. Cada proceso puede implicar el esfuerzo de una o más personas o grupos de personas, dependiendo de las necesidades del proyecto. Cada proceso tiene lugar por lo menos una vez en cada proyecto y se realiza en una o más fases del proyecto, si el proyecto se encuentra dividido en fases.

2.1. DESARROLLAR UN PLAN DE GESTIÓN DE RIESGOS

Una planificación cuidadosa y explícita mejora la posibilidad de éxito de los otros cinco procesos de gestión de riesgos. La planificación de la gestión de riesgos es el proceso de decidir cómo abordar y llevar a cabo las actividades de gestión de riesgos de un proyecto. La planificación de los procesos de gestión de riesgos es importante para garantizar que el nivel, el tipo y la visibilidad de la gestión de riesgos sean acordes con el riesgo y la importancia del proyecto para la organización, a fin de proporcionar recursos y tiempo suficientes para las actividades de gestión de riesgos, y para establecer una base acordada para evaluar los riesgos. El proceso de planificación de la gestión de riesgos debe completarse en las fases tempranas de la planificación del proyecto, dado que es crucial para realizar con éxito los demás procesos.

Es importante planificar y realizar una aproximación de las tareas relacionadas con la gestión de riesgos de un proyecto y realizar revisiones sobre dichas actividades a lo largo del proyecto.

ENTRADAS	SALIDAS	HERRAMIENTAS
– Factores ambientales de la empresa. – Activos de los procesos de la organización. – Políticas y estándares de la organización. – Enunciado del alcance del proyecto. – Plan de gestión del proyecto. – Estructura de tareas desglosada (WBS)	– Plan de gestión de riesgos	– Reuniones y análisis de planificación

Tabla 5 Entradas, salidas y herramientas del plan de gestión de riesgos

2.1.1. Dependencias

El plan de gestión de riesgos es el núcleo del proceso de planificación y depende del alcance de la definición del proyecto. Tanto los procesos de desarrollo del cronograma del proyecto como su presupuesto dependen directamente de la planificación de gestión de riesgos. Los riesgos definidos y sus correspondientes soluciones, pueden tener un impacto significativo en el coste y planificación del proyecto.

2.1.2. Tareas para la planificación de gestión de riesgos

El **propósito** del plan de gestión de riesgos es describir cómo las actividades de gestión de riesgos son organizadas y llevadas a cabo a lo largo del ciclo de vida del proyecto para asegurar que el esfuerzo invertido es el apropiado en función de la importancia del proyecto para el cliente y para la propia organización.

La planificación de riesgos es un proceso iterativo, y debe comenzar cuanto antes en las etapas de evaluación de oportunidades.

Las tareas relacionadas con este proceso son:

- Revisar entradas de riesgo
- Revisar el proceso de riesgos *end to end*
- Definir lista de actividades de gestión de riesgos
- Estimar el esfuerzo de los riesgos
- Asignar recursos a riesgos
- Definir herramientas que se van a utilizar
- Desarrollar planificación y presupuesto de riesgos

- Actualizar plan de compromisos

El plan de gestión de riesgos describe cómo se estructurará y realizará la gestión de riesgos en el proyecto. El plan de gestión de riesgos incluye:

- **Metodología**: Define los métodos, las herramientas y las fuentes de información que pueden utilizarse para realizar la gestión de riesgos en el proyecto.
- **Roles y responsabilidades**: Define el líder, el apoyo y los miembros del equipo de gestión de riesgos para cada tipo de actividad del plan de gestión de riesgos, asigna personas a estos roles y explica sus responsabilidades.
- **Preparación del presupuesto**: Asigna recursos y estima los costes necesarios para la gestión de riesgos a fin de incluirlos en la línea base de coste del proyecto.
- **Periodicidad**: Define cuándo y con qué frecuencia se realizará el proceso de gestión de riesgos durante el ciclo de vida del proyecto, y establece las actividades de gestión de riesgos que se incluirán en el cronograma del proyecto.
- **Categorías de riesgo**: Proporciona una estructura que garantiza un proceso completo de identificación sistemática de los riesgos con un nivel de detalle uniforme, y contribuye a la efectividad y calidad de la identificación de riesgos. Una organización puede usar una categorización de riesgos típicos preparada previamente. Una estructura de desglose del riesgo (RBS) es uno de los métodos para proporcionar dicha estructura donde las definiciones generales de los niveles de probabilidad e impacto se adaptan a cada proyecto individual durante el proceso de planificación de la gestión de riesgos para usarlas en el proceso de análisis cualitativo de riesgos.

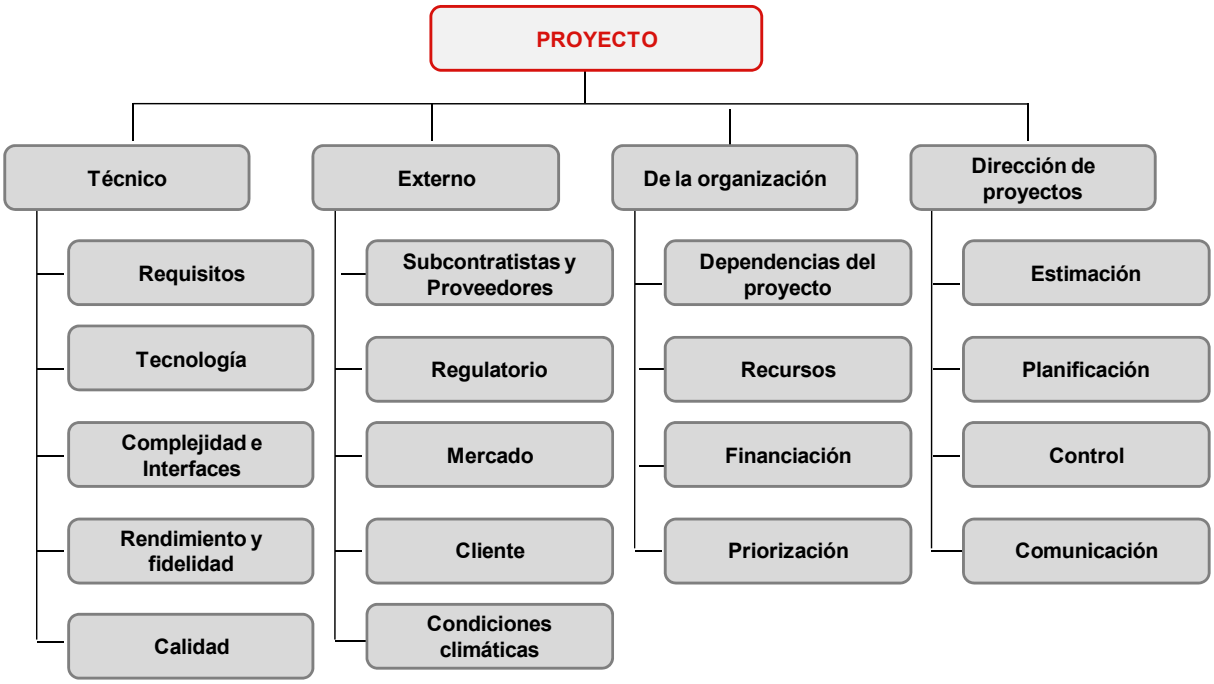


Figura 4 Ejemplo de una Estructura de Desglose de Riesgo (RBS), según PMBOK®

Los riesgos del proyecto pueden categorizarse por fuentes de riesgo, utilizando la RBS u otra clasificación útil (por ejemplo, fases del proyecto) para determinar las áreas del proyecto que están más expuestas a los efectos de la incertidumbre. Agrupar los riesgos por causas comunes puede contribuir a desarrollar respuestas efectivas a los riesgos.

Las categorías de riesgo pueden revisarse durante el proceso de identificación de riesgos. De todas formas, una buena práctica es revisar las categorías de riesgos durante el proceso de planificación de la gestión de riesgos antes de usarlas en el proceso de identificación de riesgos. Es posible que sea necesario adaptar, ajustar o extender las categorías de riesgos basadas en proyectos anteriores a las nuevas situaciones, antes de utilizarlas en el proyecto actual.

Otra de las tareas que se deberían llevar a cabo durante la etapa de planificación de gestión de riesgos es la definición general de los niveles de probabilidad e impacto del proyecto, que se utilizarán más adelante durante el análisis de riesgos. La calidad y credibilidad del proceso de análisis cualitativo de riesgos requiere que se definan los diferentes niveles de probabilidad e impacto de los riesgos, como se verá más adelante, y es en esta etapa donde se definirán.

2.2. IDENTIFICAR RIESGOS

Entradas	Salidas	Herramientas
– Categoría de riesgos – Clasificación de fuentes de riesgos – Factores ambientales de la empresa – Activos de los procesos de la organización – Enunciado del alcance del proyecto – Plan de gestión de riesgos – Plan de gestión de proyectos (WBS, agenda, recursos, requisitos, alcance, diseño,..) – Información histórica: lecciones aprendidas en otros proyectos	– Registro de riesgos o Riesgos identificados o Disparadores o Suposiciones	– Registro de riesgos – Artefactos para la identificación de riesgos (hoja de cálculo…) – Revisiones de documentación. – Técnicas especificadas en ANEXO I

Tabla 6 Entradas, salidas y herramientas de identificación de riesgos

El proceso de identificación de riesgos consiste en determinar cuáles son los riesgos que podrían afectar a los proyectos y en documentar sus características. Los roles que normalmente están involucrados en este proceso son el jefe del proyecto, los miembros del equipo del proyecto, el equipo de gestión de riesgos (si se asigna uno), expertos en la materia ajenos al equipo del proyecto, clientes, usuarios finales, otros jefes de proyectos, interesados y expertos en gestión de riesgos. Si bien estos miembros del personal son a menudo participantes clave de la identificación de riesgos, se debería fomentar la identificación de riesgos por parte de todo el personal del proyecto.

La identificación de riesgos es un proceso iterativo porque se pueden descubrir nuevos riesgos a medida que el proyecto avanza a lo largo de su ciclo de vida. La frecuencia de la iteración y quién participará en cada ciclo variará de un caso a otro. El equipo del proyecto debe participar en el proceso para poder desarrollar y mantener un sentido de pertenencia y responsabilidad de los riesgos y las acciones asociadas con la respuesta a los riesgos. Los interesados ajenos al equipo del proyecto pueden proporcionar información adicional sobre los objetivos. El proceso identificación de riesgos suele llevar al proceso de análisis cualitativo de riesgos. Como alternativa, puede llevar directamente al proceso de análisis cuantitativo de riesgos cuando lo dirige un director de riesgos experimentado. En algunas ocasiones, simplemente la identificación de un riesgo puede sugerir su respuesta, y esto debe registrarse para realizar otros análisis y para su implementación en el proceso planificación de la respuesta a los riesgos.

2.2.1. Dependencias

La identificación de riesgos es un proceso de apoyo a los procesos de planificación de proyectos y depende del desarrollo del plan de gestión de riesgos. El análisis de riesgos y la planificación de las respuestas son dependientes de la lista de riesgos identificados en este proceso.

2.2.2. Tareas para identificar riesgos

Las tareas relacionadas con el proceso de identificación de riesgos se pueden resumir en los siguientes puntos:

- Identificar riesgos
- Considerar fuentes de riesgos internos y externos
- Categorización de riesgos
- Identificación de disparadores
- Consolidación de riesgos

2.2.2.1. Identificar riesgos

El proceso de identificación de riesgos debería ser completado por el equipo de trabajo en conjunto, en lugar de hacerlo de forma individual.

Los riesgos deberían ser identificados durante:

- La determinación del alcance del proyecto
- El desarrollo de la estructura de desglose del trabajo (WBS)
- Preparación estimación de recursos, programación y costes
- Establecimiento de una línea base del contrato
- Evaluación de subcontratistas potenciales

Los documentos del proyecto, y en particular el WBS, proporcionan un excelente marco de referencia para llevar a cabo la identificación de riesgos proporcionando una manera de asegurar que los riesgos potenciales de cada área de proyecto son tratados y dirigidos.

Este proceso conlleva examinar cada paquete de trabajo individual del WBS e identificar los riesgos asociados a cada uno de ellos. Sin embargo, algunos riesgos pueden estar relacionados con el proyecto o con una actividad mayor en lugar de con un específico paquete de trabajo. Estos riesgos también necesitan ser identificados.

Puede ocurrir que se estén identificando riesgos sobre paquetes de trabajo a un nivel impráctico. Es tarea del jefe de proyecto elegir un nivel adecuado a la hora de llevar a cabo la identificación de riesgos.

Sea cual sea el nivel elegido, los elementos del WBS deberían ser revisados uno a uno. Algunas de las preguntas que se podrían hacer a la hora de revisarlos serían:

- ¿Qué podría afectar a esta tarea del proyecto?
- ¿Existen riesgos que podrían afectar a la completitud de esta tarea?
- ¿Este paquete de trabajo están en el camino crítico, y requiere una especial atención?

Cuando sea posible, los riesgos deberían hacer referencia a un paquete específico de trabajo o a un elemento del WBS. Durante el proceso de identificación de riesgos, los riesgos deberían ser simplemente plasmados en una lista y no deberían hacerse juicios acerca de su validez.

2.2.2.2. Considerar fuentes de riesgos internos y externos

Se debería considerar una amplia variedad de las posibles fuentes de los riesgos para asegurarse de que el esfuerzo de identificación de los mismos va a ser suficiente. Las fuentes de los riesgos son clasificadas normalmente en riesgos internos o externos, tal y como se explicó en anteriores apartados.

2.2.2.3. Categorización de los riesgos

La amplia variedad de riesgos en un proyecto determinado genera a menudo problemas de sobrecargada de información, provocando que ciertos riesgos sean pasados por alto o duplicados.

La categorización de los riesgos simplifica la gestión de los mismos facilitando comparaciones y toma de métricas a lo largo del proyecto.

2.2.2.4. Identificación de disparadores

A la hora de identificar riesgos es importante identificar y documentar los disparadores de cada uno de ellos. Los disparadores, a menudo llamados síntomas del riesgo o señales de aviso, son indicadores de que un riesgo ha ocurrido o está a punto de ocurrir y por lo tanto es necesario buscar un remedio. Los disparadores pueden ser eventos específicos como

por ejemplo, no cumplir ciertos hitos puede ser un disparador de un inminente retraso en la agenda programada. Estos disparadores también pueden ser umbrales predefinidos como por ejemplo, que una estimación en el desarrollo de un producto exceda el 10% de lo planificado en las primeras cuatro primeras semanas indica que se ha detectado un riesgo.

En ocasiones puede ser útil establecer disparadores tempranos que proporcionen tiempo suficiente para tratar los riesgos inminentes. Estos disparadores, al igual que los riesgos, serán controlados y revisados como parte del proceso de control y monitorización.

2.2.2.5. Consolidar y registrar los riesgos del proyecto identificados

Antes de ser analizados, los riesgos identificados deben ser registrados. Es más, los riesgos deberían ser expuestos de forma clara de tal forma que los miembros del equipo sean capaces de entender exactamente el riesgo cuando haya pasado un tiempo. La eficiencia del proceso de gestión de riesgos está relacionada directamente con cómo de bien está definido cada evento. En la descripción del riesgo se debería incluir el evento relacionado, el momento en que ocurrió y el impacto del mismo.

Además, los equipos de proyecto han de evitar generar grandes listados de riesgos al introducir riesgos insignificantes. Las amenazas y oportunidades que tengan una baja probabilidad de ocurrencia o que tengan un bajo impacto deberían ser tenidas en cuenta en futuras consideraciones. Otra posibilidad sería consolidar varios riesgos en un único riesgo que sea mayor.

El uso de **registros de riesgos** es una de las prácticas más comunes utilizadas para registrar los riesgos identificados. Este registro es utilizado normalmente en el proceso de gestión de riesgos, soportando el análisis de riesgos, la planificación de la respuesta y el control de los riesgos.

En las primeras etapas del ciclo de vida será difícil completar todo el registro de riesgos. La información mínima requerida que debe ser registrada para cada riesgo durante esta etapa de identificación es:

- Identificador del riesgo: es un identificador único para cada riesgo
- Estado del riesgo: una de las siguientes etiquetas para comunicar el estado actual del riesgo.
    - Identificado: el riesgo ha sido identificado pero no ha sido analizado ni evaluado.
    - Evaluado: un riesgo identificado que actualmente no tiene un plan de respuesta.
    - Planificado: un riesgo identificado con un plan de respuesta.
    - En proceso: un riesgo donde la respuesta al riesgo está siendo ejecutada.
    - Cerrado: un riesgo que ocurrió y que ha sido cerrado.
    - No ocurrido: un riesgo que fue identificado pero que no ocurrió. Este estado es utilizado para diferenciar entre aquellos riesgos que fueron identificados,

evaluados y gestionados hasta su cierre y aquellos que fueron identificados pero que nunca ocurrieron.

- Descripción del riesgo: la descripción del riesgo debería incluir el evento, el momento en que ocurrió y el impacto.

El equipo de proyecto revisará y consolidará esta lista asegurándose de que esta lista es manejable.

2.3. ANALIZAR RIESGOS

El análisis de riesgos evalúa los riesgos identificados en la fase anterior para determinar la probabilidad de que ocurran, el impacto del riesgo, el impacto acumulativo de múltiples riesgos y la prioridad de cada riesgo.

Las actividades relacionadas con el análisis de riesgos están divididas en tres categorías:

- **Análisis cualitativo de riesgos**: evaluación del impacto y la probabilidad de ocurrencia de los riesgos sobre las salidas del proyecto utilizando métodos cualitativos.
- **Análisis cuantitativo de riesgos:** evaluación matemática de la probabilidad de ocurrencia de cada riesgo y sus consecuencias en las salidas del proyecto.
- **Priorización del análisis**: centralizar el esfuerzo de la gestión de riesgos y ganar el mayor impacto positivo posible sobre el proyecto para dicho esfuerzo.

El análisis de riesgo debería ser revisado a través del proyecto y ajustado en función de los cambios que se vayan produciendo sobre los riesgos del proyecto. Mientras se lleva a cabo el análisis de riesgos, es importante permanecer dentro del alcance tal y como se definió en el plan de gestión de riesgos.

Entradas	Salidas	Herramientas
– Plan de gestión de riesgos – Lista de riesgos identificados (registro de riesgos) – Suposiciones – Juicio de expertos – Enunciado del alcance del proyecto – Activos de los procesos de la organización – Plan de gestión del proyecto	– Registro de riesgos actualizado – Lista de riesgos priorizados por impacto y probabilidad	– Evaluación de probabilidad e impacto de los riesgos. – Matriz de probabilidad e impacto. – Evaluación de la calidad de los datos sobre riesgos – Categorización de riesgos – Evaluación de la urgencia de riesgos – Técnicas de análisis cuantitativo de riesgos (y cualitativo)

Tabla 7 Entradas, salidas y herramientas de análisis de riesgosDependencias

El análisis de riesgos es un proceso de apoyo a los procesos de planificación de proyectos, y depende de la identificación de los riesgos del proyecto. El análisis de riesgos cuantitativo

y la planificación de respuestas son dependientes de la lista de priorización de riesgos identificados en este proceso.

2.3.1. Tareas para el análisis de riesgos

Como se especificó con anterioridad, existen tres categorías en las que se dividen las tareas relacionadas con el análisis de riesgos. A continuación se va a describir en qué consiste cada categoría y las actividades relacionadas con cada una de ellas.

- Análisis cualitativo de riesgo
    - Determinar el impacto de ocurrencia de riesgos (Cualitativo)
    - Estimar la probabilidad de ocurrencia de riesgo (Cualitativo)
- Determinar la categoría y prioridad del riesgo
- Análisis cuantitativo de riesgo
    - Determinar el impacto de ocurrencia del riesgo (Cuantitativo)
    - Estimar la probabilidad de ocurrencia de riesgo (Cuantitativo)
    - Calcular el valor esperado

2.3.1.1. Análisis cualitativo de riesgo

El análisis cualitativo del riesgo se utiliza para determinar la necesidad de encauzar los riesgos específicos y guiar la planificación de respuestas. La mejor práctica para llevar a cabo el análisis cualitativo de riesgos es la de utilizar un conjunto de valores fijos en todos los proyectos que representen la probabilidad y el impacto de cada riesgo desde un punto de vista cualitativo. Estos valores servirán para categorizar y agrupar los riesgos y proporcionar una guía sobre dónde invertir el mayor esfuerzo. Si por el contrario cada equipo eligiese sus propios valores, no existiría una base común y no se podría, por ejemplo, comparar riesgos de forma efectiva, ni determinar cómo mejora la organización en su gestión de riesgos.

La evaluación de la probabilidad de los riesgos investiga la probabilidad de ocurrencia de cada riesgo específico. La evaluación del impacto de los riesgos investiga el posible efecto sobre un objetivo del proyecto, como tiempo, coste, alcance o calidad, incluidos tanto los efectos negativos por las amenazas que implican, como los efectos positivos por las oportunidades que generan.

Para cada riesgo identificado se evalúan la probabilidad y el impacto, es decir, se asocia riesgo a riesgo un valor cualitativo de probabilidad e impacto. Los riesgos pueden ser evaluados en entrevistas o reuniones con participantes seleccionados por su familiaridad con las categorías de riesgo del orden del día. Entre ellos se incluyen los miembros del equipo del proyecto y, quizás, expertos ajenos al proyecto. Es necesario el juicio de expertos, ya que es posible que haya poca información sobre los riesgos en la base de datos de la organización de proyectos anteriores. Un facilitador experimentado puede dirigir

la discusión, ya que los participantes pueden tener poca experiencia en la evaluación de riesgos.

a) Determinar el impacto de ocurrencia de riesgos de forma cualitativa

El impacto es una estimación de la ganancia o pérdida que se sufriría en caso de que el riesgo ocurriese. El equipo del proyecto determina el impacto que tendrían los riesgos sobre todas las áreas de contrato relacionadas si el evento ocurriese.

El impacto podría afectar al coste, programación o alcance de la calidad, o a una combinación de dichos factores. El equipo debería definir no sólo cómo de grande es el impacto, sino también cuál es el elemento del proyecto más afectado.

Para soportar el análisis del impacto cualitativo, se podrían definir cuatro niveles de impacto de riesgos. La herramienta de registro de riesgos elegida debería permitir registrar uno de los siguientes valores para estimar el impacto de cada riesgo desde un punto de vista cualitativo:

Impacto	Descripción
Muy alto	Objetivos críticos (la mayor parte de ellos) del proyecto están seriamente impactados o no se cumplirán (coste, calendario, calidad o satisfacción del cliente).
Alto	Objetivos críticos (muchos de ellos) del proyecto están amenazados
Medio	Algunos objetivos del proyecto pueden verse afectados.
Bajo	Fácilmente remediable. Los objetivos del proyecto no serán afectados.

Tabla 8 Impacto de riesgos

b) Estimar la probabilidad de ocurrencia de riesgo - Cualitativo

El jefe de proyecto y el equipo analizan los riesgos identificados para determinar la probabilidad de que ocurra cada evento. Normalmente es más simple y más rápido hacerlo de forma cualitativa utilizando etiquetas de probabilidad como las que se muestran más abajo. El uso de etiquetas de probabilidad estándar asegura consistencia dentro de los equipos y a través de proyectos.

En el procedimiento de gestión de riesgos se determinarían los valores a usar para estimar la probabilidad de cada riesgo desde un punto de vista cualitativo. La herramienta de registro de riesgos debería permitir el registro de uno de los siguientes valores para cada riesgo:

Probabilidad	Descripción	Probabilidad recomendada
Muy alta 85% +	Es muy probable que ocurra el evento.	0.90
Alta 65% - < 85%	El evento ocurrirá probablemente	0.70

Media 35% - < 65%	El evento podría ocurrir.	0.45
Baja < 35%	Aunque es improbable que ocurra el evento, podría ocurrir.	0.15

Tabla 9 Probabilidad de riesgos

2.3.1.2. Determinar la categoría y prioridad del riesgo

Aunque es importante identificar el mayor número posible de riesgos del proyecto, en muchos casos el número de riesgos identificados puede ser abrumador, y lógicamente el equipo de trabajo no podrá realizar un seguimiento ni una gestión efectiva de todos ellos. Una solución sería agrupar los riesgos en función de sus prioridades de tal forma que el equipo pueda centrarse en los más críticos.

La evaluación de la importancia de cada riesgo y, por consiguiente, de su prioridad, generalmente se realiza usando una matriz de probabilidad e impacto (matriz P-I). Esta matriz asignará categorías a los riesgos basándose en la combinación de dichos factores (probabilidad e impacto) que llevan a la calificación de los riesgos como de prioridad baja, moderada o alta. Pueden usarse términos descriptivos o valores numéricos, dependiendo de la preferencia de la organización. Las reglas para calificar los riesgos pueden adaptarse al proyecto específico en el proceso planificación de la gestión de riesgos.

Una vez asociado a cada riesgo un valor estimado cualitativo de probabilidad e impacto (explicado en el apartado anterior: ***análisis cualitativo de riesgo***), se propone un ejemplo de una Matriz P-I con tres distintas clasificaciones de riesgos, basados en niveles de probabilidad e impacto de riesgo, para definir el valor cualitativo de cada riesgo.

		Probabilidad de riesgo			
		Muy alto	**Alto**	**Medio**	**Bajo**
Impacto del riesgo	**Muy alto**	Muy alto	Alto	Alto	Alto
	Alto	Alto	Alto	Medio	Medio
	Medio	Alto	Medio	Medio	Bajo
	Bajo	Bajo	Bajo	Bajo	Bajo

Tabla 10 Matriz probabilidad - impacto

De esta forma podemos seleccionar qué riesgos merecen un mayor estudio, esfuerzo y respuesta. Algunos riesgos bajos o incluso medios, son posibles candidatos a ser tratados como suposiciones. Es recomendable realizar un análisis cualitativo de las suposiciones que haya en el proyecto ya que pueden convertirse en riesgos.

En caso de que haya un número alto de riesgos dentro de la categoría 'Alto', es recomendable priorizar dichos riesgos identificando los "n" riesgos más altos dentro de esta categoría, siendo este número determinado por la organización en función de su situación. Entre los indicadores de prioridad pueden incluirse:

- Las categorías determinadas para el riesgo
- El impacto de los riesgos identificados
- El número de riesgos
- El tipo de riesgos
- El tiempo para dar una respuesta a los riesgos

El resto de riesgos no seleccionados se deberán vigilar en la fase de monitorización y control ya que pueden cambiar su estado (aumente su probabilidad o cambie su impacto potencial).

2.3.1.3. Análisis cuantitativo de riesgo

El análisis de riesgo cuantitativo es la evolución matemática de la probabilidad de cada riesgo y sus consecuencias en las salidas del proyecto. El análisis de riesgo cuantitativo utiliza técnicas para:

- Determinar la probabilidad de conseguir los objetivos específicos del proyecto
- Cuantificar el valor esperado del proyecto y sus probabilidades, y determinar el coste y la programación para reservas de contingencia
- Identificar objetivos de coste, cronograma o alcance realistas y viables

– Determinar la mejor decisión de dirección de proyectos cuando algunas condiciones o resultados son inciertos

El análisis de riesgos cuantitativo generalmente sigue al análisis de riesgos cualitativos, aunque en ocasiones se lleva a cabo directamente tras la identificación de riesgos. Los elementos de riesgos complejos pueden requerir una repetición del análisis mediante herramientas de software sofisticadas. El análisis cuantitativo de riesgos debe repetirse después de la planificación de la respuesta a los riesgos, también como parte del seguimiento y control de riesgos, para determinar si el riesgo general del proyecto ha sido reducido satisfactoriamente. Las tendencias pueden indicar la necesidad de más o menos acciones de gestión de riesgos.

El análisis cuantitativo puede ser complicado por una serie de factores:

- Los riesgos pueden interactuar de formas no esperadas
- Un único evento puede causar múltiples efectos
- Las oportunidades (reducir coste) para un involucrado en el negocio, pueden ser un riesgo para otro (reducir beneficios)
- No todos los riesgos son cuantificables, algunos pueden definirse de forma cualitativa
- Las técnicas matemáticas utilizadas pueden dar una falsa impresión de la precisión y la fiabilidad

En las situaciones anteriores, es necesario que el equipo de proyecto utilice su mejor juicio, documentando sus valoraciones y todos los factores relacionados.

a) Determinar el impacto de ocurrencia de riesgos de forma cuantitativa

Durante esta etapa, el impacto del riesgo debería cuantificarse en términos monetarios cuando sea posible. El impacto podría afectar al coste, a la programación, al alcance, a la calidad o a una combinación de los factores anteriores. El equipo debería definir no solo cómo de grande es el impacto sino también qué elementos son los más afectados y documentar los resultados en el registro de riesgos.

Por ejemplo si un riesgo implicara un coste adicional de 5000 euros, esta cantidad será identificada como el impacto asignado a dicho riesgo. O si por ejemplo un determinado evento causase un aumento de una semana en la agenda, también sería considerado como impacto de un riesgo y como tal también debería ser asociado a un coste, por ejemplo, el coste que implicaría cubrir los recursos que se van a utilizar durante esa semana. Por lo tanto, los impactos del riesgo normalmente deberían representarse en forma de costes, siempre aplicando ciertos márgenes.

b) Estimar la probabilidad de ocurrencia de riesgo de forma cuantitativa

Durante esta etapa, la probabilidad de ocurrencia del riesgo está cuantificada, dando así un valor porcentual real.

c) Calcular el valor esperado

El valor esperado es un dato estadístico que proporciona significado acerca de las pérdidas o ganancias que se tendrían en caso de que el riesgo ocurriese. Esto deriva de un simple cálculo:

Valor esperado = Impacto del riesgo * Probabilidad del riesgo

El impacto del riesgo debería indicarse en formato monetario o en duración días/semanas, y la probabilidad de riesgo será un número dentro del rango 0.01 - 0.99.

También podría tenerse en cuenta un factor para cuantificar aún más el riesgo, en cuyo caso se utilizaría la siguiente fórmula:

Impacto total de riesgo = Impacto * Probabilidad * Factor

Si se utilizan métodos cuantitativos para determinar la probabilidad y el impacto del riesgo, el proceso no es tan sencillo. En este caso la valoración a realizar es subjetiva y el único método que puede utilizarse es el método 'juicio de expertos' comentado con anterioridad, donde los expertos en la materia expresan sus opiniones sobre la probabilidad, el impacto y el riesgo total asociado a ese determinado riesgo.

Es importante ir documentando el proceso de análisis (tanto cualitativo como cuantitativo) y la priorización de los riesgos. Podría utilizarse para ello un registro de riesgos, y así ir registrando las conclusiones obtenidas del análisis de riesgos, incluyendo la prioridad, el impacto y la categoría de cada impacto.

En los procedimientos de gestión de riesgos se podrían definir, por ejemplo, la siguiente información como resultado del análisis de riesgos:

- Probabilidad cualitativa (bajo, medio, alto, muy alto)
- Impacto cualitativo (bajo, medio, alto, muy alto)
- Impacto del coste (si aplica)
- Categorías de riesgos (bajo, medio, alto; Matriz P-I)
- Probabilidad cuantitativa (%)
- Impacto cuantitativo (Euros)
- Valor esperado (si aplica)

2.4. PLANIFICAR RESPUESTAS A LOS RIESGOS

La planificación de respuestas a los riesgos es el proceso de desarrollar opciones y determinar acciones para mejorar las oportunidades y reducir las amenazas a los objetivos del proyecto. Se realiza después de los procesos análisis cualitativo de riesgos y análisis cuantitativo de riesgos. La planificación de la respuesta a los riesgos aborda los riesgos en función de su prioridad, introduciendo recursos y actividades en el presupuesto, cronograma y plan de gestión del proyecto, según sea necesario.

El plan de respuesta de riesgos documenta la estrategia de respuesta elegida para los riesgos identificados, las acciones detalladas para implementar la estrategia y quién es el responsable de los elementos de riesgo. Los planes de respuesta están integrados con la programación (agenda) y el presupuesto del proyecto para la implementación de las respuestas de riesgos. Además deben ser congruentes con la importancia del riesgo, ser aplicadas a su debido tiempo, ser realistas dentro del contexto del proyecto, estar acordadas por todas las partes implicadas, y a cargo de una persona responsable.

Para la planificación de respuestas, el equipo de proyectos debería centrarse, por lo menos, sobre los riesgos de alto impacto. Aunque el equipo de proyecto puede elegir no centrarse sobre riesgos de bajo o moderado impacto, estos riesgos han de ser monitorizados y seguidos porque su probabilidad de ocurrencia, e incluso su impacto, pueden cambiar a medida que el proyecto avanza. Lo que inicialmente fue considerado un riesgo de bajo impacto puede cambiar y transformarse en un riesgo de alto impacto.

La planificación de respuestas a los riesgos asegura una respuesta adecuada a un riesgo determinado del proyecto. Esta información crítica es utilizada a lo largo del proyecto.

Entradas	Salidas	Herramientas
– Plan de gestión de riesgos – Lista de riesgos priorizados y cuantificados – Lista de riesgos para un análisis y gestión adicional – Propietarios del riesgo	– Plan de respuesta de riesgos – Riesgos residuales – Acuerdos contractuales relacionados con el riesgo – Reserva de riesgos necesaria – Plan de gestión del proyecto actualizado – Registro de riesgos actualizado	– Registro de riesgos – Estrategias para riesgos – Estrategia de respuesta para contingencias

Tabla 11 Entradas, salidas y herramientas de planificación de respuesta de riesgos

2.4.1. Tareas para la planificación de respuestas a los riesgos

A continuación se describen las tareas relacionadas con la planificación de respuestas a los riesgos:

- Desarrollo de la estrategia de respuestas a los riesgos
  - Identificar al propietario del riesgo
- Desarrollo e implementación del plan de estrategia de riesgos
  - Evaluar y valorar la estrategia y planes de respuesta
  - Implementar planes de contingencia para los riesgos aceptados
  - Determinar riesgos residuales
- Determinar la reserva de riesgos del proyecto

Para planificar el plan de respuesta, el equipo de proyecto debería concentrarse por lo menos en aquellos riesgos con un alto impacto.

1. *Desarrollo de la estrategia de respuesta de riesgos*

El desarrollo de las estrategias de gestión de riesgos conlleva identificar varias estrategias de respuesta de riesgos para cada riesgo seleccionado, evaluar la efectividad de cada opción y seleccionar la mejor.

Para cada riesgo, pueden aplicarse varias estrategias o alternativas. El equipo de proyecto debe identificar estas alternativas, evaluar sus méritos de forma individual y seleccionar la que ofrezca la mejor solución. Puede ocurrir que el propio equipo de proyecto trabaje como grupo en el desarrollo de estrategias para cada riesgo, o bien que sea el jefe de proyecto quien divida los riesgos entre los miembros del equipo basándose en su experiencia. Cada miembro del equipo trabajaría, según este último caso, de forma independiente sobre los riesgos que tenga asignados, determinaría las opciones disponibles y seleccionaría la más apropiada. Para más información acerca de tipos de respuesta: ANEXOIII

a) *Identificar al propietario del riesgo*

Es muy importante asignar un propietario a cada riesgo. El propietario del riesgo debe involucrarse en el desarrollo de la estrategia y de acciones de respuesta para dicho riesgo y para controlar y gestionar los riesgos durante el proyecto.

El propietario del riesgo puede ser una persona externa al equipo del proyecto, por ejemplo, un representante comercial puede ser el propietario de los riesgos comerciales.

2. *Desarrollo e implementación del plan de estrategia de riesgos*

Las acciones para soportar la estrategia de respuestas, en caso de que un riesgo ocurra, están desarrolladas. Este grupo de acciones forman el **'plan de respuesta'**.

Los planes asociados a las estrategias de respuesta de riesgos 'Transferir', 'Mitigar' y 'Evitar' son implementados como parte de la estructura de desglose del trabajo (WBS) contemplando su coste en el presupuesto del proyecto. Son llevados a cabo tal y como se muestra en el plan del proyecto y de forma periódica evalúan su estado para determinar si existe la necesidad de tomar nuevas acciones.

Si la estrategia de respuesta de riesgos es 'aceptación' puede que no haya plan de respuesta (aceptación pasiva), o que exista un **'plan de contingencia'** (aceptación activa). Los planes de contingencia de los riesgos de aceptación activa, son contemplados en un registro de riesgos junto con su coste, tiempo y/o recursos necesarios para implementarlos. El coste de implementar el plan de contingencia está incluido en la reserva presupuestaria de riesgo. En este tipo de riesgos tratados de esta manera, es importante identificar y monitorizar los disparadores para determinar de forma rápida y exacta cuándo activar el plan.

El plan de contingencia se activa cuando ocurre el riesgo. Cuando sea apropiado podrá definirse un plan alternativo a utilizar en caso de que fallase el plan de contingencia. Tanto el plan de contingencia como el plan alternativo deberían estar incluidos en el plan del proyecto (tiempo, recursos, coste) y debería realizarse un seguimiento sobre los mismos, siempre que el jefe del proyecto los haya aprobado.

a) Evaluar y valorar la estrategia y planes de respuesta

El equipo del proyecto debería tener en cuenta que la implementación de una estrategia de respuestas, y las acciones que tiene asociadas, pueden crear nuevos riesgos. Cada estrategia debería ser evaluada en base a sus méritos y a cómo afectan a otros elementos del proyecto. Si se identifican riesgos adicionales, estos riesgos y sus causas deberían ser analizados.

Para minimizar estos riesgos adicionales puede ser útil revisar las siguientes preguntas:

- ¿Qué ocurrirá si se implementa la estrategia?
- ¿Esta estrategia afectará a otros paquetes de trabajo o elementos del proyecto?
- ¿Cuál será la probabilidad de ocurrencia del riesgo si se implementa esta estrategia?
- ¿Esta es la mejor estrategia?
- ¿Cuáles serían los impactos adicionales de precio/programación en el caso en que los paquetes de trabajo se vean afectados?

b) Implementar planes de contingencia para los riesgos aceptados

Cuando ocurre un riesgo, se utilizan estrategias de respuesta de aceptación, tanto pasivas como activas. Para asegurar que la respuesta de los riesgos es implementada según lo planificado, el propietario del riesgo, y responsable del elemento del WBS relacionado con dicho riesgo, controla el estado del riesgo hasta su cierre.

Implementar un plan de contingencia requiere la utilización de la reserva de riesgos, y que se realice un seguimiento del esfuerzo invertido en el plan de contingencia. Después de activar la estrategia de aceptación, el jefe de proyecto debe revisar el plan del proyecto para reflejar el coste de la implementación de la acción (tiempo, personas y dinero). Esta revisión, que es necesaria ya que el coste no está incluido en la estimación original, debería ser registrada en el registro de riesgos.

c) Determinar riesgos residuales

Después de haber desarrollado e implementado un plan de respuesta, puede que el riesgo no se consiga eliminar completamente, o que dicha implantación implique nuevas actividades en el proyecto que afecten a otros elementos del mismo, pudiendo crear nuevos riesgos. Por este motivo es importante asignar responsables de los riesgos (propietarios de los riesgos), que se encargarán de mantener el estado de los riesgos, monitorizarlos, implementar planes de respuesta…

Cualquier riesgo que permanezca, que no consiga ser eliminado, tras haber implantado un plan de respuesta de un riesgo se llama **'riesgo residual',** y debería ser identificado y analizado como cualquier otro riesgo. Es particularmente importante para estos riesgos las estrategias de mitigar, transferir o evitar ya que el valor esperado de los riesgos residuales está incluido en el presupuesto de reserva de riesgos**.**

3. *Determinar la reserva de riesgos del proyecto*

Una reserva de riesgos presupuestaria es un colchón en el presupuesto del proyecto utilizado para reducir el impacto negativo de riesgos (o incrementar los positivos), respetando los márgenes establecidos para el proyecto. La reserva de riesgos incluye una **'reserva de contingencia'** y una **'reserva de gestión'** cuyo propietario es el jefe del proyecto, que siempre tiene que contar con la aprobación de la empresa.

La reserva de contingencia es la suma del valor esperado para los riesgos con una estrategia de respuesta de 'aceptación' y el valor esperado para riesgos residuales, por ejemplo, para aquellos con estrategias de respuesta como 'mitigación' y 'transferencia' (riesgos conocidos pero no controlables). La reserva de gestión, sin embargo, depende de la incertidumbre de los proyectos (riesgos no conocidos).

Un problema importante a tener en cuenta en la reserva de riesgos son los riesgos desconocidos del proyecto. El método recomendado para tratar este problema es añadir una única entrada en el registro de riesgos para todo este conjunto de riesgos desconocidos tratándolos como otro riesgo más, dándoles una descripción, calculando su probabilidad e impacto y desarrollando una estrategia de respuesta de '**aceptación'**. A continuación se muestra un ejemplo de una entrada a un registro de riesgos para riesgos desconocidos:

Descripción del riesgo	**Probabilidad**	**Impacto**	**Valor riesgo**
Riesgos desconocidos	Media	Media	Media
$ Coste Impacto	**(% * $) Valor esperado**	**Propietario del riesgo**	**Estrategia de respuesta de riesgos**
$75,000	$33,750	Jefe del proyecto	Aceptación

Tabla 12 Ejemplo entrada registro de riesgos

Una vez que se ha estimado la reserva de riesgo debería ser validada. El porcentaje de riesgos desconocidos dentro de la reserva de riesgos es un indicador de todos los riesgos del proyecto. En el presupuesto deberían incluirse otros costes asociados a riesgos (con una estrategia de respuesta de **'mitigar', 'transferir' o 'evitar'**), no en la reserva de riesgos. Solamente los valores esperados de riesgos residuales procedentes de estas estrategias deberían incluirse en la reserva de riesgos.

2.4.2. Herramientas

Los resultados del registro de riesgos pueden plasmarse por ejemplo en una hoja Excel. Dicha hoja podría utilizarse como entrada para los planes de respuesta de riesgos como indicador de la importancia de los riesgos sobre ciertas áreas del entorno del proyecto. Las áreas con alta sensibilidad deberían tener planes de respuesta de riesgos y de planes alternativos más detallados y completos.

El registro de riesgos debería ser utilizado para registrar los planes de respuesta de, por lo menos, aquellos riesgos dentro de la categoría 'Alta'. También debería mostrar la suma de los valores esperados para aquellos riesgos que contribuyen a la estimación de reserva de riesgos de proyectos, incluyendo aquellos riesgos desconocidos.

Del plan de repuesta de riesgos se debería recoger la siguiente información:

- Propietario del riesgo
- Estrategia de respuesta (si aplica)
- Descripción de la respuesta (si aplica)

2.5. CONTROLAR Y MONITORIZAR RIESGOS

Las respuestas planificadas a los riesgos que están incluidas en el plan de gestión del proyecto se ejecutan durante el ciclo de vida del proyecto, pero deben ser supervisadas continuamente para detectar riesgos nuevos o cambiantes.

Controlar y monitorizar riesgos es un proceso que consiste en controlar los disparadores de riesgos (si ha saltado alguno), gestionar los riesgos identificados, realizar seguimientos sobre los riesgos residuales, descubrir nuevos riesgos, ejecutar planes de respuesta de riesgos y evaluar la efectividad de las acciones de respuesta. El proceso de seguimiento y control de riesgos, así como los demás procesos de gestión de riesgos, es un proceso continuo que se realiza durante la vida del proyecto. Un control efectivo y una monitorización adecuada de los riegos proporcionan avisos tempranos de los riesgos y ayudan a ejecutar una toma de decisiones efectivas. Durante este proceso es necesario que haya una comunicación periódica con los propietarios de las respuestas de los riesgos y los involucrados del proyecto sobre el estado de los riesgos.

La monitorización de riesgos determina si:

- Los planes de respuesta de los riesgos han sido implementados de la forma adecuada.
- Los planes de respuesta de los riesgos son efectivos o si es necesario el desarrollo de nuevos planes.
- Las suposiciones de los riesgos continúan siendo válidas.
- Un disparador del riesgo ha ocurrido.
- Se han seguido las políticas de la empresa.
- Han aparecido riesgos no identificados.

El control de riesgos normalmente implica elegir nuevas estrategias de respuesta, ejecutar planes de contingencia, tomar acciones correctivas o modificar planes del proyecto. Los propietarios de las respuestas de los riesgos deberían informar de la efectividad del plan de respuesta, riesgos secundarios, estados de riesgos residuales y cambios en la estrategia de respuesta.

Entradas	Salidas	Herramientas
– Plan de gestión de riesgos – Plan de respuesta a los	– Documentación adicional sobre riesgos del proyecto, incluyendo	– Registro de riesgos – Auditorías de los riesgos

riesgos – Comunicación del proyecto – Cambios de alcance – Identificación y análisis de riesgos adicionales – Registro de riesgos – Solicitudes de cambio aprobadas – Informes de rendimiento	planes temporales, planes de acción correctiva, solicitudes de cambio. – Lecciones aprendidas – Actualizaciones de información de riesgos, planes de respuesta y estado de registro de riesgos – Plan de gestión del proyecto actualizado – Acciones correctivas y preventivas recomendadas	– Medición del rendimiento – Reuniones sobre el estado de la situación

Tabla 13 Entradas, salidas y herramientas de control y monitorización de riesgos

2.5.1. Dependencias

El control y monitorización de los riesgos es un proceso soportado por todos los procesos de control de todo el proyecto. Este proceso es dependiente de la información proporcionada por las comunicaciones del proyecto y cualquier cambio en el alcance del mismo. El control y monitorización de los riesgos puede influir en otros procesos del proyecto al ejecutar acciones correctivas y solicitudes de cambio.

2.5.2. Tareas para controlar y monitorizar riesgos

Los planes de respuesta de riesgos deben ser evaluados de forma continua, y actualizados a lo largo de la implementación del proyecto. Debe documentarse cuándo y cómo se ha llevado a cabo en el **plan de gestión de riesgos**. Es muy importante valorar el efecto que produce el plan de respuesta a los riesgos para realizar ajustes e incluso actualizar dicho plan para realizar una gestión de riesgos efectiva.

El registro de riesgos y su efectividad deberían evaluarse según se indica a continuación:

- Revisar el estado de los riesgos con el equipo en reuniones periódicas.
- Revisar el estado de los riesgos con el cliente en reuniones periódicas.
- Hitos principales del proyecto.
- Como parte del proceso de control de cambios del proyecto.

Los riesgos, su probabilidad de ocurrencia y su impacto están continuamente cambiando. Aparecen nuevos riesgos y los antiguos desaparecen. Implementar acciones de mitigación de riesgos puede crear nuevos riesgos no predecibles, o cambiar el efecto de riesgos ya existentes. Por lo tanto evaluar de forma periódica el plan es una actividad esencial, y las revisiones periódicas deberían ser especificadas en la programación del proyecto.

Los grandes hitos son puntos importantes en la gestión del proyecto. Ayudan a evaluar cómo va el proyecto y evaluar los cambios en el entorno. Cada vez que se propone un importante cambio en el proyecto y se aprueba su implementación, el equipo del proyecto debería estudiar cómo afectará este cambio al proyecto y determinar si se introducirán

nuevos riesgos debidos al cambio. También será necesario desarrollar nuevas estrategias de respuestas a estos riesgos.

Otros disparadores que pueden provocar una evaluación de los riesgos son:

- Variación significativa en los costes respecto a lo esperado
- Inconsistencia en la programación/agenda respecto a lo esperado
- Cambios en las predicciones de fechas del proyecto
- Cambios en la actitud de los involucrados en el negocio
- Cualquier cambio durante el proyecto que amenace los objetivos del mismo.

Para realizar la valoración y actualización del registro de riesgos seguir los siguientes pasos:

- Revisar los planes de respuesta de los riesgos que han sido implementados para evaluar su efectividad y detectar la necesidad de tomar acciones correctivas.
- Revisar y actualizar la probabilidad, impacto, prioridad y el estado de los riesgos previamente identificados.
- Desarrollar nuevas estrategias de respuesta de riesgos o modificar las antiguas en caso de que la estrategia actual no funcione según lo previsto.
- Evaluar los riesgos mayores de los elementos WBS actualmente implementados para comprobar si ha habido cambios o si las estrategias deberían haberse modificado.
- Identificar nuevos riesgos, analizarlos e incorporarlos en el proceso de gestión de riesgos del proyecto. También desarrollar los planes y estrategias de respuesta correspondientes.
- Actualizar el plan del proyecto para que refleje cambios en los planes de respuesta de riesgos.
- Volver a analizar los riesgos residuales previamente filtrados, o aquellos riesgos con una categoría media o alta.
- Volver a evaluar la reserva de riesgos del proyecto para determinar si el buffer existente del proyecto es suficiente.
- Determinar si los umbrales y disparadores establecidos se han modificado (aumentaron) o si el plan de reserva de riesgos es probable que sea sobrepasado.

Una buena práctica sería documentar los esfuerzos de respuesta de riesgos en el registro de riesgos para generar un histórico de las acciones y resultados obtenidos. De esta manera los jefes de proyecto pueden aprender de experiencias pasadas, como por ejemplo, podrán conocer qué estrategias y acciones llevadas a cabo funcionaron y cuáles no. La documentación de la gestión de riesgos (plan de gestión de riesgos, registro de riesgos y herramientas asociadas) debería desarrollarse de la forma más simple posible, a la vez que debe ser completa, exacta y estar actualizada.

2.5.3. Herramientas

El jefe de proyectos debería utilizar el registro de riesgos de forma regular registrando el estado de cada elemento de riesgo. Cualquier cambio en la información o el estado de los riesgos debería comunicarse tan pronto como sea posible. El estado de cada riesgo, la estrategia de respuestas y los costes planificados deberían grabarse.

La información a obtener al ejecutar el proceso de control y monitorización de los riesgos dependerá de los intereses de la empresa. A continuación se propone un ejemplo de la información que se podría almacenar:

- Identificador del riesgo
- Estado del riesgo
- Descripción del riesgo
- Probabilidad cualitativa (baja, media, alta, muy alta)
- Impacto cualitativo (bajo, medio, alto, muy alto)
- Impacto de costes
- Categorización de riesgos cualitativa (bajo, medio, alto, calculado por matriz P-I)
- Probabilidad cuantitativa (%)
- Impacto cuantitativo (Euros)
- Valor esperado
- Estrategia de respuesta
- Descripción de respuesta

2.6. CIERRE DE LA GESTIÓN DE RIESGOS

Compartir lecciones aprendidas es un recurso muy valioso en el ámbito de la gestión de riesgos. Estas lecciones pueden proporcionar experiencia general sobre el proceso de gestión de riesgos y su relación con las salidas del proyecto. Las lecciones aprendidas deberían se capturadas a lo largo de todo el ciclo de vida del proyecto, no solamente en esta última etapa de cierre del proyecto. Por ejemplo, una posibilidad podría ser capturar dichas lecciones durante las reuniones de revisiones de proyectos o de riesgos. Una vez capturadas deben compartirse y han de estar en concordancia con la política y procedimientos de la organización. Las siguientes preguntas podrían ayudar a identificar estas lecciones:

- Qué se ha hecho bien
- Qué deberíamos haber hecho mejor o de otra forma
- Podrían hacerse posibles mejoras o cambios en el proceso de gestión de riesgos y en las herramientas existentes.

Entradas	Salidas	Herramientas
– Plan de gestión de riesgos – Planes de respuesta a los riesgos desde el registro de riesgos – Comunicación de riesgos – Realimentación del equipo	– Lecciones aprendidas documentadas en un informe del cierre del proyecto. – Mejoras registradas para el proceso, plantillas y herramientas de la gestión de riesgos – Mejoras registradas para otros procesos del proyecto, plantillas y herramientas	– Registro de riesgos

Tabla 14 Entradas, salidas y herramientas del cierre de gestión de riesgos

2.6.1. Dependencias

El cierre de la gestión de riesgos depende del conjunto de lecciones aprendidas a través del ciclo de vida. Durante el cierre del proyecto estas lecciones se organizan como parte del proceso de informes del cierre del proyecto y se comparte con el resto de profesionales de la empresa.

2.6.2. Tareas del cierre de gestión de riesgos

Las tareas relacionadas con el cierre del proceso de gestión de riesgos son:

- Capturar lecciones aprendidas
- Proporcionar entradas al cierre del proyecto

3. ARTEFACTOS RELACIONADOS CON GESTIÓN DE RIESGOS

Existen distintos documentos que pueden ayudar a una organización en las tareas relacionadas con la gestión de riesgos. En esta sección se van a proponer algunos modelos o plantillas que pueden ayudar a la hora de crear dichos documentos.

Estas plantillas o modelos pretenden ser una guía a la hora de crear documentos relacionados con la gestión de riesgos.

- **Plantilla de gestión de riesgos**: plantilla para registrar, analizar, planificar y controlar los riesgos de un proyecto.
- **Checklist de identificación de riesgos:** lista de comprobación para asegurar que se está siguiendo adecuadamente el proceso definido para la identificación de riesgos.
- **Checklist de riesgos:** lista de riesgos identificados en otros proyectos de las mismas características para ayudar a la identificación de riesgos del proyecto actual.
- **Plantilla de estrategia de gestión de riesgos:** el proceso de gestión de riesgos tiene que asegurar que el nivel, tipo y visibilidad de la gestión de riesgos es proporcional al riesgo y a la importancia del proyecto. Mediante este documento se van a describir las actividades asociadas a la gestión de riesgos, siendo éstas asignadas a las distintas personas implicadas. Se ha de establecer la forma en la que se va a medir el impacto y la probabilidad de los riesgos y por la tanto la valoración final de los mismos.
- **Plantilla de registro de riesgos:** sirve como registro de los riesgos identificados, así como para el análisis, planificación de respuesta, monitorización y control de los mismos. En la plantilla se han definido unos valores modelo que aparecen en las tablas de la parte inferior y que son los que aparecen en las listas desplegables de cada una de las columnas. La valoración de los riesgos se hace en función del impacto y la probabilidad, para los que se han definido una serie de valores posibles, que pueden ser modificados de acuerdo a las necesidades. Éstos deberían ser consistentes con los datos expuestos en la estrategia de gestión de riesgos.

Algunos ejemplos de estos artefactos y herramientas pueden encontrarse en los servicios online de ‘Directorio de herramientas’ y ‘Repositorio documental de procesos’ disponibles de forma gratuita en el portal de INTECO (www.inteco.es), en su sección de ‘Calidad de software’.

4. ENFOQUE DE ALGUNOS MODELOS

4.1. CMMI® VS SPICE

El modelo SPICE describe los procesos que una organización debe ejecutar para adquirir, proveer, desarrollar, operar, evolucionar y dar soporte al software, y las prácticas genéricas que caracterizan la capacidad de esos procesos.

Cada proceso del modelo se describe en términos de prácticas básicas, que son las actividades esenciales de un proceso específico. El modelo clasifica los procesos en cinco categorías que son: Cliente-Proveedor, Ingeniería, Proyecto, Soporte y Organización.

La categoría Proyecto consiste en una serie de procesos que coordinan y gestionan los recursos de los proyectos para producir un producto, o proporcionar servicios que satisfagan al cliente. Dentro de esta categoría está el proceso **MAN.5 Gestión de riesgos**.

El propósito del proceso de gestión de riesgos es identificar, analizar, tratar y monitorizar los riesgos de forma continua de un proyecto a lo largo de todo su ciclo de vida. Según SPICE la gestión de riesgos consiste en identificar nuevos riesgos, trabajar para mitigarlos de forma efectiva y evaluar el éxito de los esfuerzos de mitigación. Las prácticas relacionadas con este proceso son:

- MAN.5.1 Establecer el alcance de la gestion de riesgos
- MAN.5.2 Definir estrategias de gestión de riesgos
- MAN.5.3 Identificar riesgos
- MAN.5.4 Analizar riesgos
- MAN.5.5 Definir y realizar acciones de tratamiento de riesgos
- MAN.5.6 Monitorizar los riesgos
- MAN.5.7 Tomar acciones preventivas o correctivas

CMMI® es un modelo de madurez de mejora de procesos para el desarrollo y mantenimiento de productos y servicios. Consiste en una serie de mejores prácticas que dirigen las actividades de desarrollo y mantenimiento que cubren el ciclo de vida del producto.

Al igual que ocurre en SPICE, el modelo CMMI® organiza sus áreas de proceso en categorías: Gestión de proceso, Gestión de proyecto, Ingeniería y Soporte. El área de proceso ‘Gestión de riesgos’ está englobada en la categoría de ‘Gestión de proyecto’.

Según CMMI® la gestión de riesgos está dividida en 3 partes:

- Definir una estrategia de gestión de riesgos
- Identificar y analizar los riesgos

- Manejar los riesgos identificados, incluyendo la implementación de planes de mitigación cuando sea necesario.

En las áreas de proceso 'Planificación de proyectos' y 'Control y monitorización de proyectos', las organizaciones inicialmente se centran en identificar los riesgos simplemente para tener conocimiento de ellos y reaccionar cuando apareciesen. El área de proceso 'Gestión de Riesgos' describe una evolución de estas prácticas, planificando, anticipándose y mitigando riesgos para minimizar de forma proactiva su impacto sobre el proyecto.

Las prácticas que propone seguir CMMI® para llevar a cabo con éxito una gestión de riesgos son:

- SG1 Prepararse para una gestión de riesgos
  - SP 1.1 Determinar recursos y categorías
  - SP 1.2 Definir parámetros de riesgos
  - SP 1.3 Establecer una estrategia de gestión de riesgos
- SG2 Identificar y analizar los riesgos
  - SP 2.1 Identificar los riesgos
  - SP 2.2 Evaluar, categorizar y priorizar riesgos
- SG 3 Mitigar riesgos
  - SP 3.1 Desarrollar planes de mitigación de riesgos
  - SP 3.2 Implementar planes de mitigación de riesgos

4.2. PMBOK® VS PRINCE2

PRINCE procede de las siglas **Pr**ojects **IN** **C**ontrolled **E**nvironments y es un método estructurado para una gestión de proyectos efectiva sobre todo tipo de proyectos, no solamente para sistemas de información, aunque la influencia de esta industria sobre la metodología es clara. Es un estándar ampliamente reconocido por el gobierno de UK, aunque también es reconocido y utilizado por el sector público y privado de Europa, Asia, Canadá y UK.

PRINCE2 nació en 1996 por la CCTA (Central Computer and Telecommunications Agency). PRINCE2 sustituyó a una versión anterior, PRINCE, originalmente desarrollada en 1989, basada en PROMPT, un método de gestión de proyectos creado por Simpact Systems Ltd en 1975.

La versión PRINCE2 es el resultado obtenido de la experiencia de jefes y equipos de proyectos. PRINCE2 es una marca registrada de OGC, pero su contenido es claramente genérico. Por ejemplo, la introducción de PRINCE2 propone un conjunto de razones por las que los proyectos fallan. La metodología se establece para eliminar estas causas.

Toda esta documentación debe ser adaptada a cada ocasión. Por ejemplo, PMBOK® no pretende decir a la gente que utilicen las técnicas y herramientas descritas. Simplemente establece una serie de procesos, explica cómo se relacionan y las herramientas y técnicas

que pueden invocarse. De forma similar, la aplicación de PRINCE2 debe ser escalada en función del tamaño y necesidades del proyecto. De hecho, la escalabilidad es un tema que está incluido en la descripción de cada proceso.

Proyecto de ciclo de vida y grandes procesos

La primera diferencia es que PRINCE2 es claramente un ciclo de vida de proyecto basado en seis grandes procesos que se ejecutan desde el "comienzo del proyecto" hasta el "cierre del proyecto". Además tiene otros dos procesos, "planificación" y "dirección de un proyecto", que son procesos continuos, y soportan a los otros seis procesos. Cada uno de estos ocho procesos, tiene sus respectivos sub procesos. Estos sub procesos son 45 en total. PRINCE2 a su vez describe seis componentes, los cuales unos son documentos y otros procesos, y también describe tres técnicas: "producto basado en planificación", "revisión de calidad", y "control de cambios". El documento entero está redactado de una forma narrativa, fácil de seguir.

PMBOK®, a diferencia de PRINCE2, consiste en 12 capítulos que describen funciones basadas en áreas de conocimiento con ilustraciones de sus respectivos procesos de gestión de proyecto y descripciones narrativas en forma de entradas, herramientas y técnicas, y salidas. PRINCE2 habla de "etapas" en vez de "fases", y establece que mientras el uso de dichas etapas es obligatorio, su número es flexible dependiendo de los requisitos de gestión del proyecto.

PMBOK® define una fase del proyecto como una colección de actividades relacionadas con el proyecto, que normalmente finalizan con la creación de un entregable mayor. Esta guía no distingue entre fases y etapas, utiliza ambos conceptos indistintamente.

PRINCE2 describe la vida de un producto en 5 etapas: comienzo, viabilidad, implementación, operación y terminación. De todas estas etapas, PRINCE2 solamente cubre la implementación. De hecho, lo que se entiende por "etapas" en PRINCE2, serán divisiones de "implementación" de la vida del producto para PRINCE2. Por lo tanto, PRINCE2 es una metodología de implementación, más relacionada con la gestión de la "construcción" que con la gestión propiamente del proyecto entero.

Niveles y responsabilidades de gestión

PRINCE2 reconoce 4 niveles paralelos de gestión: “Gestión corporativa o de programa”, “Dirección de un proyecto”, “Gestión de un proyecto” y “Gestión de la entrega de un producto”. De esta forma, el negocio corporativo o intereses de la gestión de programas están integrados tanto con la gestión del proyecto (a nivel de proyecto) como con la gestión de la tecnología del proyecto (a nivel de equipo).

Otra característica interesante es la responsabilidad del jefe del proyecto. PMBOK® define un jefe de proyecto como un individuo responsable de la gestión de un proyecto. El Instituto de Ingeniería de Software (SEI) va aún más allá definiéndolo como la persona con total responsabilidad de negocio para un proyecto entero. Esta persona será la encargada de dirigir, controlar, administrar el proyecto, y en última instancia es el responsable ante el usuario final.

Por el contrario, bajo el enfoque de PRINCE2 el jefe de proyecto es la persona con autoridad y responsabilidad para gestionar el proyecto, y de la entrega del producto de acuerdo a las restricciones previamente acordadas. Estas restricciones hacen referencia a los rangos de aceptación del alcance, calidad, tiempo y costes del proyecto. Cualquier tendencia hacia estos límites puede transformarse en un problema.

La junta responsable del proyecto está presidida por una persona que será un ejecutivo; una persona que tendrá la responsabilidad real del proyecto. Este individuo se asegura de que el proyecto o programa mantiene su foco de negocio, que tiene una clara autoridad y que el trabajo, incluyendo riesgos, está correctamente gestionado. Esta persona que preside la junta responsable del proyecto representa al cliente y es el propietario del caso de negocio. Este individuo podría equipararse al director de un proyecto, que proporciona liderazgo al proyecto, mientras que el jefe de proyecto está relacionado con las actividades de gestión del mismo.

Haciendo referencia a los diferentes enfoques que PMBOK® y PRINCE2 dan a ambos roles, PMBOK® no reconoce a una persona ejecutiva que preside a la junta responsable del proyecto, utiliza el término “sponsor”. El sponsor es uno de los involucrados en el negocio y se define como el individuo o grupo, interno o externo a la organización, que proporciona recursos financieros a la misma. Por lo tanto, según la guía de PMBOK®, sería el jefe de proyecto quién está firmemente a cargo.

Planificación y programación

La planificación basada en productos es una característica clave de PRINCE2, poniendo el foco sobre los productos que se van a entregar y en su calidad, entendiendo por producto cualquier documento o parte del software.

En el PMBOK® la planificación es tratada como una parte clave de las habilidades de la gestión de un proyecto. Es uno de los 5 grupos de proceso aplicados a cada fase y es reconocido como un esfuerzo que va en progreso a lo largo de la vida del proyecto. La planificación es discutida en el capítulo ‘Gestión de integración del proyecto’, aunque aparece en cada área de conocimiento y debe ser integrado a través de ellos.

En resumen, PRINCE2 y PMBOK® tienen enfoques muy diferentes. Realmente atienden a distintos propósitos y por esta razón no son comparables. PMBOK® se centra en trasmitir el contenido de cada área de conocimiento, no siendo tan efectivo al proporcionar guías al ejecutar un proyecto en particular. Por otra parte, como el enfoque que da PRINCE2 está orientado al ciclo de vida, es difícil ajustarlo a cada área de conocimiento.

Otra diferencia es que mientras que PRINCE2 está diseñado para una variedad de situaciones de clientes y/o proveedores, la guía de PMBOK® se ha desarrollado bajo la suposición de que el proyecto será llevado a cabo por un solo cliente y con un solo proveedor.

A la hora de describir un proyecto, PMBOK® explica que los proyectos a menudo son implementados como un medio para conseguir el plan de estrategia de la organización y por lo tanto todos los niveles de la organización se comprometen con ellos. La guía cubre más terreno que PRINCE2, aunque PRINCE2 proporciona una metodología muy robusta y fácil de seguir para llevar a cabo la mayoría de los proyectos, donde los objetivos son claros y los entregables están bien descritos y son fáciles de seguir.

5. ANEXO I: MÉTODOS DE IDENTIFICACIÓN DE RIESGOS

A continuación se describen algunas de las técnicas más utilizadas a la hora de identificar riesgos, y una serie de buenas prácticas a tener en cuenta a la hora de poner en la práctica el proceso de identificación de riesgos.

5.1. TÉCNICAS DE IDENTIFICACIÓN DE RIESGOS

Existen múltiples técnicas que pueden ayudar a identificar riesgos. En este apartado se proponen algunas de las más conocidas.

5.1.1. Técnicas de Recopilación de Información

5.1.1.1. Tormenta de ideas

La tormenta de ideas es una herramienta de trabajo grupal que facilita el surgimiento de ideas sobre un tema. La lluvia o tormenta de ideas, habitualmente conocida como “brainstorming”, es una técnica de grupo para generar ideas originales en un ambiente relajado. La meta de la tormenta de ideas es obtener una lista completa de los riesgos del proyecto. El equipo del proyecto suele realizar tormentas de ideas, a menudo con un grupo multidisciplinario de expertos que no pertenecen al equipo. Se generan ideas acerca de los riesgos del proyecto bajo el liderazgo de un facilitador. Los riesgos luego son identificados y categorizados por tipo y sus definiciones son refinadas.

5.1.1.2. Técnica Delphi

La técnica Delphi es una forma de llegar a un consenso de expertos. Es la búsqueda de consenso entre especialistas (expertos) sobre eventos futuros. Los expertos en riesgos de proyectos participan en esta técnica de forma anónima. Un facilitador emplea un cuestionario con definición clara de objetivos y resultados deseados, para solicitar ideas acerca de los riesgos importantes del proyecto. Las respuestas son resumidas y luego enviadas nuevamente a los expertos para que realicen comentarios adicionales. En pocas rondas de este proceso se puede lograr el consenso. La técnica Delphi ayuda a reducir sesgos en los datos y evita que cualquier persona ejerza influencias impropias en el resultado.

Esta técnica está caracterizada por realizar cuestionarios de forma anónima, con un tratamiento estadístico simple y una re evaluación de respuestas para nuevo cuestionario. Los expertos que forman parte de esta técnica han de tener un amplio conocimiento sobre los riesgos.

5.1.1.3. Entrevistas

Entrevistar a participantes experimentados del proyecto, interesados y expertos en la materia puede servir para identificar riesgos. Las entrevistas son una de las principales fuentes de recopilación de datos para la identificación de riesgos.

5.1.2. Técnica de organización de información

5.1.2.1. Diagramas de afinidad

Es una forma de organizar la información reunida por ejemplo en sesiones de lluvia/tormenta de ideas. El diagrama de afinidad ayudará a agrupar elementos que están relacionados, en este caso los riesgos. Tras finalizar una lluvia de ideas, por ejemplo, se transfieren todos los datos a notas (post it). Luego se reúnen todas estas notas en grupos similares, y las notas que sean similares se consideran de “afinidad mutua”. Una vez agrupadas y revisadas, se asigna un nombre a cada grupo de notas por medio de discusión en grupo, de tal forma que dicho nombre transmita el significado de las notas en muy pocas palabras.

Después de que los grupos estén ordenados, se deben pegar las notas (Post it) en una hoja de rotafolio. Las tarjetas de los títulos se deberán colocar en la parte superior del grupo. Por último, el equipo deberá discutir la relación de los grupos y sus elementos correspondientes con el problema.

El uso de un diagrama de afinidad es un proceso creativo que produce consenso por medio de la clasificación que hace el equipo en vez de una discusión. El diagrama de afinidad generalmente se relaciona con:

- Lluvia de ideas
- Diagramas de árbol
- Diagramas de causa - efecto

5.1.3. Análisis mediante lista de control

Las listas de control para identificación de riesgos pueden ser desarrolladas basándose en información histórica y en el conocimiento que ha sido acumulado de proyectos anteriores similares y de otras fuentes de información. El nivel más bajo de la RBS también puede utilizarse como lista de control de riesgos. Si bien una lista de control puede ser rápida y sencilla, es imposible elaborar una que sea exhaustiva. Se debe tener cuidado de explorar elementos que no aparecen en la lista de control. La lista de control debe revisarse durante el cierre del proyecto, a fin de mejorarla para su uso en futuros proyectos.

5.1.4. Análisis de suposiciones

Todos los proyectos se conciben y desarrollan sobre la base de un grupo de hipótesis, escenarios o suposiciones. El análisis de suposiciones es una herramienta que explora la

validez de las asunciones según su aplicación en el proyecto. Identifica los riesgos del proyecto debidos al carácter inexacto, inconsistente o incompleto de las suposiciones.

5.1.5. Técnicas de diagramación

Las técnicas de diagramación de riesgos pueden incluir:

- **Diagramas de causa y efecto**: estos diagramas son útiles para identificar las causas de los riesgos.
- **Diagramas de flujo o de sistemas:** estos diagramas muestran cómo se relacionan los diferentes elementos de un sistema, y el mecanismo de causalidad.
- **Diagramas de influencias:** estos diagramas son representaciones gráficas de situaciones que muestran las influencias causales, la cronología de eventos y otras relaciones entre variables y resultados.

5.2. BUENAS PRÁCTICAS

Algunas buenas prácticas recomendables a la hora de identificar riesgos son:

- Examinar cada elemento de la estructura de desglose del trabajo (WBS)
- Búsqueda de datos en el histórico de proyectos similares para desarrollar un listado de riesgos potenciales, con la ayuda de lecciones aprendidas
- Revisar esfuerzo de gestión de riesgos de proyectos similares
- Examinar documentación o base de datos de las lecciones aprendidas
- Entrevista a expertos en la materia
- Entrevista a involucrados en el negocio – clientes, subcontratista, proveedor, terceras partes
- Examinar fuentes especificas de riesgos del proyecto en documentos relacionados con:
    - Definición de alcance
    - Especificación de requisitos
    - Especificación de diseño
    - Documentos relacionados con solicitud de propuestas
    - SOW (Statement of Work)
    - Acuerdos del contrato
- Analizar áreas de incertidumbre
- Analizar razones por las que se han tomado las decisiones

6. ANEXO II: METODOLOGÍAS Y TÉCNICAS DE ANÁLISIS DE RIESGOS

6.1. TÉCNICAS DE ANÁLISIS DE RIESGOS

A continuación se describen algunas de las técnicas más utilizadas en el análisis de riesgos. Estas técnicas se podrían categorizar de varias formas. Este apartado clasifica las técnicas en función del tipo de análisis: cualitativo o cuantitativo.

6.1.1. Técnicas de valoración cualitativa de riesgos (análisis cualitativo)

6.1.1.1. Delphi

La técnica Delphi es de utilidad cuando se quiere llegar a un consenso entre un número de personas evitando la influencia entre las mismas. La técnica Delphi es utilizada en multitud de situaciones. Un ejemplo de ello es su uso durante la fase de identificación de riesgos. También se suele utilizar durante la fase de análisis cualitativo del proceso de gestión de riesgos.

6.1.1.2. Matriz probabilidad – impacto

La matriz de probabilidad impacto es una técnica comúnmente utilizada para realizar valoraciones cualitativas de riesgos. Se explica en más profundidad en el apartado de análisis de riesgos.

6.1.2. Técnica de valoración cuantitativa (análisis cuantitativo)

6.1.2.1. CBA (Cost Benefit Analysis)

El análisis coste-beneficio puede ser de ayuda para realizar juicios sobre si las medidas tomadas para la reducción de riesgos son o no factibles, es decir, si su coste no es desproporcionadamente grande frente a sus beneficios. Por ello todos los elementos o puntos positivos deberían situarse “en un lado de la balanza” y los negativos “en la otra parte de la balanza” para ver qué merece la pena. Por ejemplo, si una compañía quisiera comprar un nuevo producto software para mejorar su negocio y quisiese saber si le sale rentable tendría en una parte de la balanza:

- El precio del software
- El cose de las personas que instalarán e implementarán el software
- El coste de formación para los usuarios del software

Y por otro lado:

- Se mejorarían los procesos de negocio

- Se tendría mejor información disponible, por lo que se podría hacer una mejor toma de decisiones

De esta forma la compañía vería si debería o no comprar el software, en función de su situación y necesidades.

6.1.2.2. Modelado y Simulación

Las simulaciones utilizan un modelo de proyecto que traduce las incertidumbres específicas a un nivel detallado en impacto potencial sobre los objetivos a nivel de proyecto. Las simulaciones de proyecto utilizan modelos de computación y estimaciones de riesgo normalmente expresadas como una distribución de probabilidad de coste y duración posible a nivel detallado de trabajo. La técnica más utilizada suele ser el análisis Monte Carlo.

La simulación utiliza una representación o modelo de un sistema para analizar el comportamiento esperado o rendimiento de un sistema. Para usar la simulación Monte Carlo se debe tener 3 estimaciones (muy probable, pesimista, optimista) más una estimación de la probabilidad de la estimación existente entre los valores más optimistas y probables.

Los pasos a seguir serían:

1. Valorar el rango de variables a considerar.
2. Determinar la probabilidad de distribución de cada variable.
3. Para cada variable seleccionar un valor aleatorio basándose en la distribución de probabilidad.
4. Ejecutar un análisis determinista.
5. Repetir los pasos 3 y 4 para obtener la distribución de probabilidad de los resultados del modelo.

6.1.2.3. Análisis del valor ganado

El análisis del valor monetario esperado es un concepto estadístico que calcula el resultado promedio cuando el futuro incluye escenarios que pueden ocurrir o no (es decir, análisis con incertidumbre). El valor monetario esperado de las oportunidades generalmente se expresará con valores positivos, mientras que el de los riesgos será negativo. El valor monetario esperado se calcula multiplicando el valor de cada posible resultado por su probabilidad de ocurrencia, y sumando los resultados. Este tipo de análisis se usa comúnmente en el análisis mediante árbol de decisiones. Se recomienda el uso del modelado y la simulación para el análisis de los riesgos de costes y del cronograma, porque son más efectivos y están menos sujetos a errores de aplicación que el análisis del valor monetario esperado.

6.1.2.4. Árboles de decisión

Los árboles de decisión son útiles a la hora de seleccionar el mejor camino de acción cuando las salidas futuras son inciertas.

El análisis mediante árbol de decisiones normalmente se estructura usando un diagrama de árbol de decisiones (figura 11-12) que describe una serie de posibles alternativas a elegir y las implicaciones de elegir unas u otras y los posibles escenarios. Incorpora el coste de cada opción disponible, las probabilidades de cada escenario posible y las recompensas de cada camino lógico alternativo. Es utilizado cuando escenarios futuros o salidas de acciones son inciertos. Incorpora probabilidades y los costes de cada camino lógico de eventos y futuras decisiones, y utiliza análisis de valor monetario esperado para ayudar a la organización a identificar los valores relativos de acciones alternativas.

6.1.2.5. Análisis de sensibilidad

El análisis de sensibilidad ayuda a determinar qué riesgos tienen el mayor impacto posible sobre el proyecto. Este método examina la medida en que la incertidumbre de cada elemento del proyecto afecta al objetivo que está siendo examinado, cuando todos los demás elementos inciertos se mantienen en sus valores de línea base. Una representación típica del análisis de sensibilidad es el diagrama con forma de tornado, que es útil para comparar la importancia relativa de las variables que tienen un alto grado de incertidumbre con aquellas que son más estables.

6.2. METODOLOGÍAS

Conocer el riesgo al que están sometidos los elementos de trabajo es, simplemente, imprescindible para poder gestionarlos y por ello han aparecido multitud de metodologías y herramientas de soporte que buscan objetivar el análisis para saber cuán seguros (o inseguros) están y no llamarse a engaño. El gran reto de todas estas aproximaciones es la complejidad del problema al que se enfrentan; complejidad en el sentido de que hay muchos elementos que considerar y que, si no se es riguroso, las conclusiones serán de poco fiar. El temor a lo desconocido es el principal origen de la desconfianza y, en consecuencia, aquí se busca conocer para confiar: conocer los riesgos para poder afrontar los y controlarlos.

6.2.1. MAGERIT

MAGERIT es una metodología de carácter público, perteneciente al Ministerio de Administraciones Públicas (MAP). Su utilización no requiere autorización previa del MAP. Magerit interesa a todos aquellos que trabajan con información y los sistemas informáticos que la tratan. Si dicha información o los servicios que se prestan gracias a ella son valiosos, esta metodología les permitirá saber cuánto de este valor está en juego y les ayudará a protegerlo.

Magerit persigue los siguientes objetivos:

- Concienciar a los responsables de los sistemas de información de la existencia de riesgos y de la necesidad de atajarlos a tiempo
- Ofrecer un método sistemático para analizar tales riesgos
- Ayudar a descubrir y planificar las medidas oportunas para mantener los riesgos bajo control

- Apoyar la preparación a la organización para procesos de evaluación, auditoría, certificación o acreditación, según corresponda en cada caso
- Así mismo, se ha cuidado la uniformidad de los informes que recogen los hallazgos y las conclusiones de un proyecto de análisis y gestión de riesgos: modelo de valor, mapa de riesgos, evaluación de salvaguardas, estado de riesgo, informe de insuficiencias, y plan de seguridad

MAGERIT describe la metodología desde tres ángulos:

- Describe los pasos para realizar un análisis del estado de riesgo y para gestionar su mitigación. Es una presentación netamente conceptual.
- Describe las tareas básicas para realizar un proyecto de análisis y gestión de riesgos, entendiendo que no basta con tener los conceptos claros, sino que es conveniente pautar roles, actividades, hitos y documentación para que la realización del proyecto de análisis y gestión de riesgos esté bajo control en todo momento.
- Uno de sus capítulos aplica la metodología al caso del desarrollo de sistemas de información, en el entendimiento que los proyectos de desarrollo de sistemas deben tener en cuenta los riesgos desde el primer momento, tanto los riesgos a los que están expuestos, como los riesgos que las propias aplicaciones introducen en el sistema.
- Como complemento desgrana una serie de aspectos prácticos, derivados de la experiencia acumulada en el tiempo para la realización de un análisis y una gestión realmente efectivos.

La herramienta PILAR es un procedimiento informático-lógico para el análisis y la gestión de los riesgos de un sistema de información siguiendo la metodología MAGERIT.

La herramienta PILAR es de uso exclusivo en la administración pública española. Se puede descargar de http://www.ar-tools.com/pilar.

6.2.2. OCTAVE

Evalúa amenazas y vulnerabilidades de los recursos tecnológicos y operacionales importantes de una organización. El método OCTAVE (Operationally Critical Thereat, Asset and Vulnerability Evaluation) permite la comprensión del manejo de los recursos, identificación y evaluación de los riesgos que afectan la seguridad dentro de una organización. Exige llevar la evaluación de la organización y del personal de la tecnología de información (IT) por parte del equipo de análisis mediante el apoyo de un patrocinador interesado en la seguridad.

Las funciones del equipo de análisis:

- Identificar los recursos importantes mediante encuestas y entrevistas.
- Realizar actividades de análisis de riesgo.
- Relacionar amenazas y vulnerabilidades.

- Crear estrategias de protección, planes de mitigación y diseñar políticas de seguridad.

Octave es una marca registrada en la oficina de patentes y negocios de EEUU. Es una marca de servicio registrada por Carnegie Mellon Univeristy

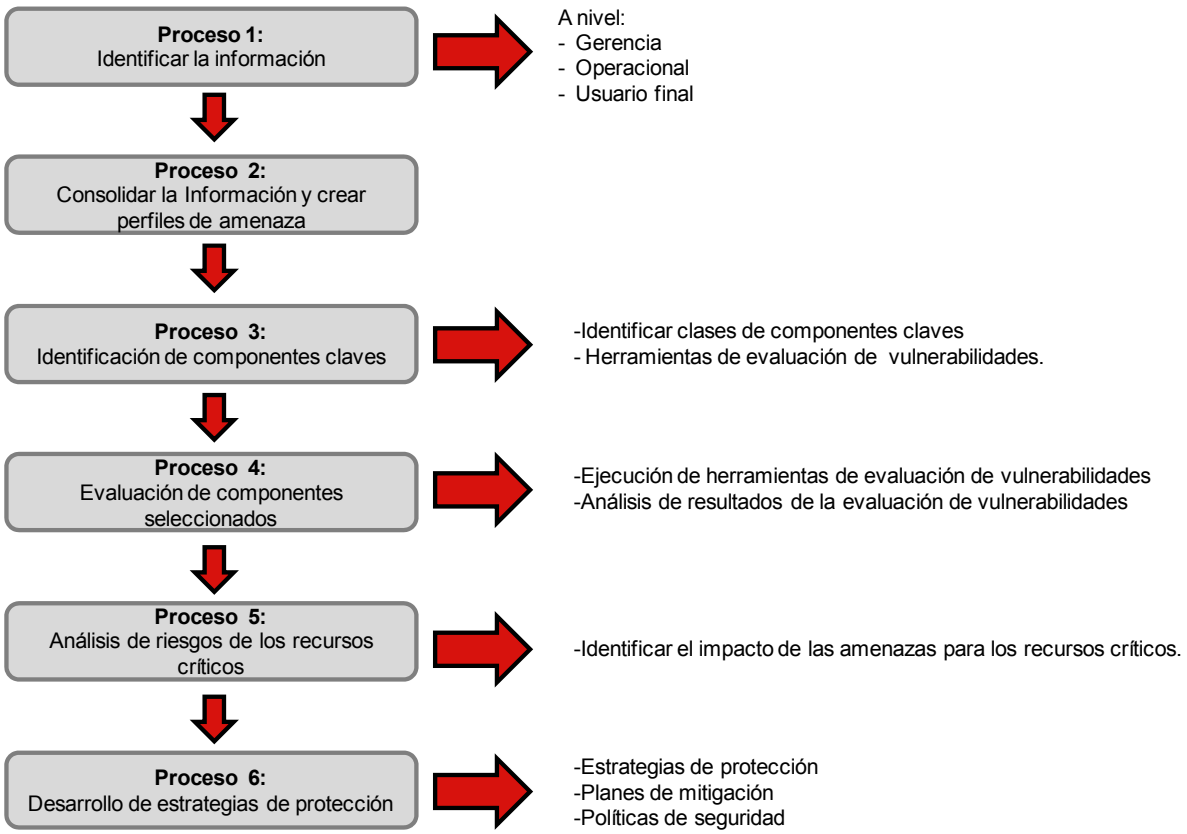


Figura 5 Procesos metodología Octave

6.2.3. NIST 800-30ª

NIST 800-30ª es una metodología basada en los conceptos generales presentados en el Instituto Nacional de los Estándares y la Tecnología (NIST, National Institute of Standards and Technology).

El propósito de la guía es dar unos principios del desarrollo de un programa de gestión de riesgos y proporcionar información de controles de seguridad a un coste efectivo.

La guía tiene distintas secciones:

- La sección 2 proporciona una visión general sobre la gestión de riesgos, explica cómo encaja dentro del ciclo de vida de desarrollo del proyecto y los roles de las personas que soportan y utilizan este proceso.
- La sección 3 describe la metodología de evaluación del riesgo y los 9 pasos primarios para dirigir una evaluación de riesgos de un sistema de IT.
- La sección 4 describe el proceso de mitigación de riesgos, incluyendo estrategias de mitigación de riesgos, enfoque a implementación y categorías de control, análisis coste-beneficios y riesgos residuales.
- La sección 5 discute las buenas prácticas y la necesidad de evaluar la progresión de los riesgos, y los factores que conducirán a un programa de gestión de riesgos exitoso.

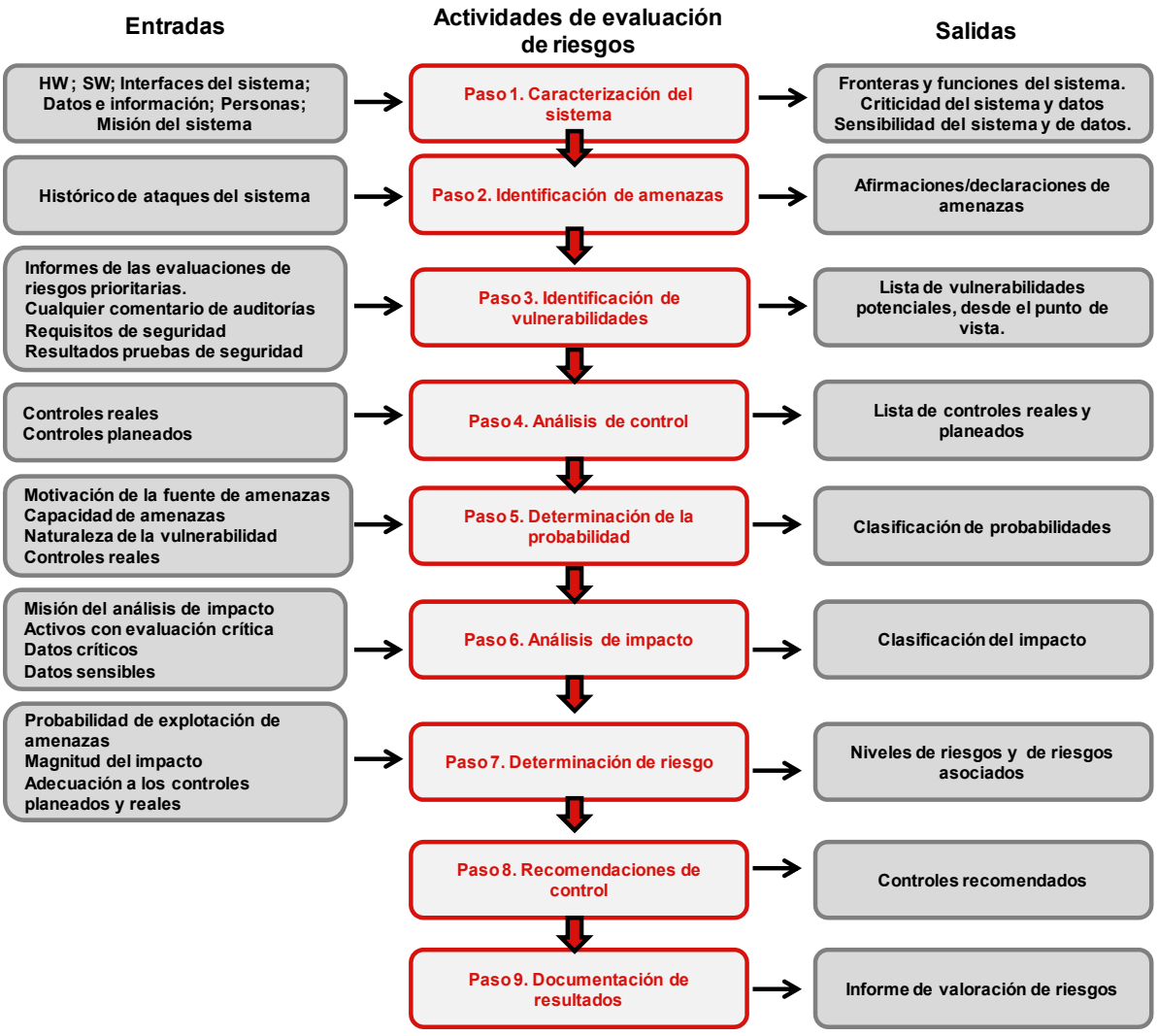


Figura 6 Flowchart de metodología de evaluación de riesgos. Fuente NIST 800-30ª

7. ANEXO III: ESTRATEGIAS DE RESPUESTAS

Existen distintas estrategias de respuesta a los riesgos. Es importante seleccionar la más efectiva dentro de cada proyecto. Parar elegir la correcta, puede ser de ayuda el uso de herramientas de análisis de riesgos como por ejemplo el uso de árboles de decisiones.

Luego se desarrollan acciones específicas para implementar esa estrategia. Se pueden seleccionar estrategias principales y de refuerzo. También puede desarrollarse un plan de reserva, que será implementado si la estrategia seleccionada no resulta ser totalmente efectiva o si se produce un riesgo aceptado. A menudo, se asigna una reserva para contingencias de tiempo o coste. Finalmente, pueden desarrollarse planes para contingencias, junto con la identificación de las condiciones que disparan su ejecución.

7.1. ESTRATEGIAS PARA RIESGOS NEGATIVOS O AMENAZAS

Existen tres estrategias que normalmente se ocupan de las amenazas o los riesgos que pueden tener impactos negativos sobre los objetivos del proyecto en caso de ocurrir. Estas estrategias son evitar, transferir o mitigar.

7.1.1. Evitar

Evitar el riesgo implica cambiar el plan de gestión del proyecto para eliminar la amenaza que representa un riesgo adverso, aislar los objetivos del proyecto del impacto del riesgo o disminuir el objetivo que está en peligro. Normalmente se elimina la causa del mismo (cambiando una situación), de tal forma que el riesgo no pueda afectar al proyecto. Ejemplos de este tipo de estrategia sería reducir el alcance para evitar ciertas actividades, añadir recursos, extender la programación o adoptar tecnología estable.

Algunos riesgos que surgen en las etapas tempranas del proyecto pueden ser evitados aclarando los requisitos, obteniendo información, mejorando la comunicación o adquiriendo experiencia. Se trata de eliminar un riesgo específico, normalmente eliminando la causa del mismo (cambiando una situación) de tal forma que el riesgo no pueda afectar al proyecto. Ejemplos de este tipo de estrategia serían reducir el alcance para evitar ciertas actividades, añadir recursos, extender la programación o adoptar tecnología estable.

7.1.2. Transferir

Transferir el riesgo requiere trasladar el impacto negativo de una amenaza y la responsabilidad del mismo a un tercero para su gestión. No se elimina el riesgo, pero se minimizan las consecuencias para la empresa. Transferir la responsabilidad del riesgo es más efectivo cuando se trata de exposición a riesgos financieros. Transferir el riesgo casi siempre supone el pago de una prima de riesgo a la parte que toma el riesgo. Las herramientas de transferencia pueden ser bastante diversas e incluyen, entre otras, el uso de seguros, garantías de cumplimiento, certificados de garantía, etc. Pueden usarse contratos para transferir a un tercero la responsabilidad por riesgos especificados. En muchos casos, se puede usar un tipo de contrato de costes para transferir el riesgo de

costes al comprador, mientras que un contrato de precio fijo puede transferir el riesgo al vendedor, si el diseño del proyecto es estable.

7.1.3. Mitigar

Mitigar el riesgo implica reducir la probabilidad y/o el impacto de un evento de riesgo adverso a un umbral aceptable. Adoptar acciones tempranas para reducir la probabilidad de la ocurrencia de un riesgo y/o su impacto sobre el proyecto a menudo es más efectivo que tratar de reparar el daño después de que ha ocurrido el riesgo.

Normalmente esto requiere cambios en el plan del proyecto, como por ejemplo añadir actividades y recursos, adoptar procesos menos complejos, realizar más pruebas o seleccionar un proveedor más estable para tratar de forma proactiva el riesgo. Todos estos son ejemplos de acciones de mitigación (**plan de mitigación)**. Los costes asociados a los planes de respuesta con estrategias de mitigar, transferir y evitar deben ser incluidos en el presupuesto del proyecto, no en el presupuesto de reserva de riesgos ya que en estos casos se sabe qué coste y cuándo se acomete para responder a cada riesgo.

Donde no es posible reducir la probabilidad, una respuesta de mitigación puede tratar el impacto del riesgo, dirigiéndose específicamente a los elementos que determinan su severidad. Por ejemplo, diseñando redundancia en un subsistema se puede reducir el impacto que resulta de un fallo del componente original.

7.2. ESTRATEGIAS PARA RIESGOS POSITIVOS U OPORTUNIDADES

Se sugieren tres respuestas para tratar los riesgos que tienen posibles impactos positivos sobre los objetivos del proyecto. Estas estrategias son explotar, compartir o mejorar.

7.2.1. Explotar

Se puede seleccionar esta estrategia para los riesgos con impactos positivos, cuando la organización desea asegurarse de que la oportunidad se haga realidad. Esta estrategia busca eliminar la incertidumbre asociada con un riesgo del lado positivo en particular haciendo que la oportunidad definitivamente se concrete. Explotar las respuestas directamente incluye asignar recursos más talentosos al proyecto para reducir el tiempo hasta la conclusión, o para ofrecer una mejor calidad que la planificada originalmente.

7.2.2. Compartir

Compartir un riesgo positivo implica asignar la propiedad a un tercero que está mejor capacitado para capturar la oportunidad para beneficio del proyecto. Entre los ejemplos de acciones para compartir se incluyen: formar asociaciones de riesgo conjunto, equipos, empresas con finalidades especiales o uniones temporales de empresas, que se pueden establecer con la finalidad expresa de gestionar oportunidades.

7.2.3. Mejorar

Esta estrategia modifica el “tamaño” de una oportunidad, aumentando la probabilidad y/o los impactos positivos, e identificando y maximizando las fuerzas impulsoras clave de estos riesgos de impacto positivo. Buscar facilitar o fortalecer la causa de la oportunidad, y dirigirse de forma proactiva a las condiciones que la disparan y reforzarlas, puede aumentar la probabilidad. También puede centrarse en las fuerzas impulsoras del impacto, buscando aumentar la susceptibilidad del proyecto a la oportunidad.

7.3. ESTRATEGIA COMÚN ANTE AMENAZAS Y OPORTUNIDADES

7.3.1. Aceptar

Estrategia se adopta debido a que rara vez es posible eliminar todo el riesgo de un proyecto. Esta estrategia indica que el equipo del proyecto ha decidido no cambiar el plan de gestión del proyecto para hacer frente a un riesgo, o no ha podido identificar ninguna otra estrategia de respuesta adecuada, y puede ser adoptada tanto para las amenazas como para las oportunidades. Esta estrategia puede ser pasiva o activa. La aceptación pasiva no requiere acción alguna, dejando en manos del equipo del proyecto la gestión de las amenazas o las oportunidades a medida que se producen. La estrategia de aceptación activa más común es establecer una reserva para contingencias, que incluya la cantidad de tiempo, dinero o recursos necesarios para manejar las amenazas o las oportunidades conocidas, o incluso también las posibles y desconocidas.

7.4. ESTRATEGIA DE RESPUESTA PARA CONTINGENCIAS

Algunas respuestas están diseñadas para ser usadas únicamente si tienen lugar determinados eventos. Para algunos riesgos, resulta adecuado que el equipo del proyecto prepare un plan de respuesta que sólo se ejecutará bajo determinadas condiciones predefinidas, si se cree que habrá suficientes señales de advertencia para implementar el plan. Los eventos que disparan la respuesta para contingencias, como no cumplir con hitos intermedios o ganar una prioridad más alta con un proveedor, deben ser definidos y seguidos.

Estrategia riesgos amenazas	Estrategia riesgos oportunidades	Estrategia común ante amenazas y oportunidades	Estrategia de respuesta para contingencias
Explotar	Evitar	Aceptar	Condiciones predefinidas
Compartir	Transferir		
Mejorar	Mitigar		

Tabla 15 Estrategias de respuesta de riesgos

Puede ser interesante realizar una matriz que relacione los riesgos con los planes de respuesta. Puede pasar que un plan pueda tratar a varios riesgos. A continuación se propone un ejemplo de las estrategias asignadas a unos riesgos, clasificados en función de su impacto.

Riesgos	Impacto	Cómo manejarlos
Conocido	Conocido	Prevenir o aceptar (Evitar, minimizar impacto, transferir)
Conocido	No Conocido	Prevenir, mitigar o aceptar (Evitar, asegurar, transferir)
No Conocido	No Conocido	Gestión de reserva de riesgos (Reserva de coste y agenda para contingencia)

Tabla 16 Ejemplo estrategias asignadas a riesgos

8. GLOSARIO

- **Activo:** cualquier recurso de software, harware, datos, administrativo, físico, de personal de comunicaciones…
- **Amenaza:** una amenaza es la posibilidad de que una fuente de amenazas ejecute una determinada vulnerabilidad de forma satisfactoria. Es un peligro latente que si se anticipa puede producir efectos negativos sobre los proyectos. Es un factor de riesgos externo que se expresa como la probabilidad de que un evento negativo se produzca.
- **Análisis de riesgos:** proceso de evaluar riesgos ya identificados para estimar su impacto y probabilidad de ocurrencia.
- **Análisis cualitativo de riesgo**: evaluación del impacto y la probabilidad de ocurrencia de los riesgos sobre las salidas del proyecto utilizando métodos cualitativos.
- **Análisis cuantitativo de riesgo:** evaluación matemática de la probabilidad de ocurrencia de cada riesgo y sus consecuencias en las salidas del proyecto.
- **Categoría de riesgos:** grupos para organizar los riesgos y así ayudar durante las distintitas fases del proceso de gestión de riesgos.
- **Disparador:** indicador de que un riesgo ha ocurrido o está a punto de ocurrir.
- **Estrategia de pruebas:** el desarrollo de las estrategias de gestión de riesgos conlleva identificar varias estrategias de respuesta de riesgos para cada riesgo seleccionado, evaluar la efectividad de cada opción y seleccionar la mejor. Para cada riesgo, pueden aplicarse varias estrategias o alternativas.
- **Evitar riesgos:** esta técnica del proceso del plan de respuesta de riesgos implica un cambio en el plan del proyecto para eliminar riesgos.
- **Fuente de riesgos:** una fuente de riesgos potenciales que reflejan fuentes técnicas, de gestión de proyecto, organizacionales y externas.
- **Gestión de riesgos:** aplicación de procedimientos y prácticas en relación a los riesgos que amenazan un proyecto en la organización.
- **Hoja de rotafolio:** atril en que se colocan hojas grandes de papel para escribir o dibujar durante una clase, charla o conferencia.
- **Identificación de riesgos:** determinar qué riesgos pueden afectar al proyecto y documentar sus características.
- **Identificación de riesgos:** determinar los riesgos que afectan al compromiso del plan de gestión de riesgos y documentar las características de riesgos.
- **Identificación de riesgos:** proceso de identificar riesgos usando técnicas tales como brainstorming, checklist e histórico de fallos.

- **Impacto:** el impacto es la materialización de un riesgo; una medida del grado de daño o cambio sobre un activo, entendiendo como riesgo la probabilidad de que un evento desfavorable ocurra y que tendría un impacto negativo si se llegase a materializar.
- **Mitigación de riesgos:** planificación y ejecución de medidas de intervención dirigidas a reducir o disminuir el riesgo existente. La mitigación asume que en muchas circunstancias no es posible controlar el riesgo totalmente, es decir, que en muchos casos no es posible impedir o evitar totalmente los daños y sus consecuencias, sino más bien reducirlos a niveles aceptables por la propia organización.
- **Monitorización y control de riesgos:** monitorizar los riesgos residuales, identificar nuevos riesgos, ejecutar los planes de respuesta de riesgos y evaluar su efectividad a través del ciclo de vida del proyecto.
- **Plan de contingencia**: procedimientos operativos específicos y preestablecidos de coordinación, alerta y respuesta ante la ocurrencia de un riesgo.
- **Plan de gestión de riesgos:** documento que describe la estrategia que se va a seguir en el proyecto, y cómo las actividades de gestión de riesgos van a ser organizadas y llevadas a cabo durante la vida del proyecto, es decir, a las actividades relacionadas con la reducción, previsión y control de riesgos, la preparación ante riesgos y la recuperación en caso de desastre. El plan de gestión de riesgos es la salida resultante de la fase de planificación de gestión de riesgos.
- **Planificación de gestión de riesgos:** es la fase del proceso de gestión de riesgo en la que se decide el enfoque y se desarrolla el plan que van a seguir las actividades de gestión de riesgos para un compromiso (plan de gestión de riesgos).
- **Plan de respuesta de riesgos:** un documento detallado de todos los riesgos identificados, incluyendo la descripción, causa, probabilidad de ocurrencia, impacto sobre objetivos, respuestas planificadas, propietarios de riesgos y estado actual. El plan de respuesta contiene las acciones para soportar la estrategia de respuestas, en caso de que un riesgo ocurra.
- **PMBOK®:** guía de fundamentos de dirección de proyectos. Estándar más ampliamente reconocido para gestionar y administrar proyectos.
- **Prevención de riesgos:** medidas y acciones dispuestas con anticipación que buscan prevenir nuevos riesgos o impedir que aparezcan. Se trabaja en torno a amenazas y vulnerabilidades.
- **Registro de riesgos:** es una de las prácticas más comunes utilizadas para grabar los riesgos identificados. Este registro es utilizado normalmente en el proceso de gestión de riesgos, soportando el análisis de riesgos, la planificación de la respuesta y el control de los riesgos.
- **Reserva de riesgos:** una provisión en el presupuesto del proyecto para reducir el riesgo de que el presupuesto del proyecto exceda un cierto nivel establecido por la

empresa. La reserva de riesgos cubrirá tanto la reserva de contingencia como le reserva de gestión, y su propietario será el jefe del proyecto.

- **Reserva de contingencia:** esta reserva está orientada a riesgos que sólo pueden ser planificados de forma parcial. Incluye la aceptación de riesgos y riesgos residuales (riesgos no conocidos, controlables)
- **Reserva de gestión:** coste estimado para eventos imprevisibles (riesgos no conocidos, imprevisibles e incontrolables)
- **Riesgo:** un evento no certero o condición que, si ocurriese, tendría un efecto positivo o negativo sobre los objetivos del proyecto. Los riesgos negativos pueden llamarse 'amenazas', y los riesgos positivos 'oportunidades'. Normalmente expresado como impacto y probabilidad.
- **Riesgo de un proyecto:** un riesgo de un proyecto es un evento o condición incierto que, si se produce, tendrá un efecto positivo o negativo sobre al menos un objetivo del proyecto, como tiempo, coste, alcance o calidad,
- **Riesgo residual:** un riesgo que permanece después de que las respuestas de riesgos hayan sido implementadas.
- **SOW (Statement of Work):** propuesta de trabajo donde se especifican los requisitos a alto nivel del trabajo que se va a realizar.
- **Suposiciones:** las suposiciones son afirmaciones aceptadas como reales pero sin ningún tipo de prueba que las sustente. Con el tiempo se puede determinar si las suposiciones son verdaderas o falsas.
- **Vulnerabilidad:** una vulnerabilidad es una debilidad que puede ser 'activada' de forma accidental o intencionadamente. Es un factor de riesgo interno de un elemento expuesto a una amenaza de ser susceptible a sufrir un daño y de encontrar dificultades en recuperarse posteriormente.
- WBS (Work Breakdown Structure): estructura de desglose de trabajo que consiste en la división de un proyecto en tareas y sub-tareas.

9. REFERENCIAS

A. Abran, J.W. Moore, P. Bourque, R. Dupuis, *Guide to the Software Engineering Body of Knowledge*, IEEE Computer Society, 2004.

Andrea Golze, Charlie Li y Shel Prince, "*Optimize Quality for Business Outcomes - A practical approach to software testing" (*2005)

Boehm, Barry, *"Software Risk Management",* (1989)

Dorothy Graham, Erik Van Veenendaal, Isabel Evans y Rex Black, *"Foundations of Software Testing - ISTQB® Certification"* (2007)

INTECO, *Guía de mejores prácticas de calidad de producto*, 2007.

Jones, Capers, "*Assessment and Control of Software Risks"*, (1994)

K.E. Emam, J.N. Drouin, W. Melo, *SPICE: The Theory and Practice of Software Process Improvement and Capability Determination*, IEEE Computer Society Press, 1998.

M.B. Chrissis, M. Konrad, S. Shrum, *CMMI® Second Edition. Guidelines for Process Integration and Product Improvement,* Addison-Wesley, 2007.

Enlaces

MAGERIT - *Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información,* http://www.csi.map.es/csi/pg5m20.htm

NIST 800-30ª - *National Insitute of Standard and Technology,* http://csrc.nist.gov/publications/nistpubs/800-30/sp800-30.pdf

OCTAVE, http://www.utpl.edu.ec/eccblog/wp-content/uploads/2007/04/articulo-tecnico-evaluacion-de-amenazas-y-vulnerabilidades-de-recursos-criticos-operacionalesoctave-a-nivel-de-usuario-final-para-la-utpl.pdf

PMI - *Project Management Institute,* www.pmi.org

PRINCE2 - ***PR****ojects* ***IN C****ontrolled* ***E****nvironments,* www.prince2.com/

SEI - Software Engineering Institute, www.sei.cmu.edu/